

CESAR SCHOOL

MARCELO WANDERLEY LIMA

CARCARÁ: UMA ABORDAGEM LEVE PARA MODELAGEM DE AMEAÇAS EM
AMBIENTES ÁGEIS

Recife

2026

MARCELO WANDERLEY LIMA

CARCARÁ: UMA ABORDAGEM LEVE PARA MODELAGEM DE AMEAÇAS EM
AMBIENTES ÁGEIS

Dissertação de Mestrado apresentada ao Programa de Mestrado Profissional em Engenharia de Software CESAR SCHOOL, como requisito parcial para obtenção do título de Mestre em Engenharia de Software.

Orientador:: Dr. Carlos Diego Cavalcanti Pereira

Recife

2026

Permito a reprodução, total ou parcial, deste trabalho por quaisquer meios físicos ou digitais, exclusivamente para fins de estudo e pesquisa, desde que a fonte seja devidamente referenciada.

Catalogação da Publicação na Fonte (CIP)
Centro de Estudos e Sistemas Avançados do Recife - CESAR School
Bibliotecária Ana Clara Amorim, CRB-2145.

L732c Lima, Marcelo Wanderley
 Carará: uma abordagem leve para modelagem de ameaças
 em ambientes ágeis Marcelo Wanderley Lima ; orientação
 Carlos Diego Cavalcanti Pereira. -- Recife : CESAR
 School, 2026.
 111 p. il.

 Dissertação (Mestrado) - Programa de Pós-graduação
 em Engenharia de Software do Centro de Estudos e Sistemas
 Avançados do Recife.

 1. Segurança de Software. 2. Métodos Ágeis. 3. DevSecOps.
 4. Shift-left. 5. Modelagem de ameaças. 6. Segurança
 da informação I. Pereira, Carlos Diego Cavalcanti. II. Lopes
 Júnior, Petrónio Gomes. III. Firmo, André Caetano Alves.
 IV. Título.



MARCELO WANDERLEY LIMA

TÍTULO

CARCARÁ: UMA ABORDAGEM LEVE PARA MODELAGEM DE AMEAÇAS EM
AMBIENTES ÁGEIS

Trabalho aprovado em Recife: 04/03/2026

Professor:

Dr. Carlos Diego Cavalcanti Pereira
Orientador

Professor:

Dr. Petrônio Gomes Lopes Júnior
Avaliador Interno

Professor:

Dr. André Caetano Alves Firmo
Avaliador Externo - PPGEC-UPE

RECIFE

2026

Dedico este trabalho à minha esposa, Carolina Coimbra e às minhas filhas, Maria Luísa e Maria Alice, minha fonte inesgotável de amor, inspiração e força. Sou profundamente grato por cada palavra de incentivo, cada gesto de apoio e pelo companheirismo incondicional.

AGRADECIMENTOS

Registro meu reconhecimento especial ao amigo Breno, que tive a felicidade de conhecer durante o mestrado, agradeço pela orientação e pelo incentivo constante para encarar de frente os desafios que surgiram nesta pesquisa.

A Carlos Diego, cuja contribuição foi essencial para o desenvolvimento desta pesquisa, deixo meu sincero reconhecimento pela disposição em colaborar e compartilhar conhecimento.

Minha profunda gratidão ao meu irmão, Igor José, pela parceria, paciência e companheirismo, sempre presente em cada etapa deste processo.

Ao amigo Edivaldo Júnior, pelas valiosas aulas de modelagem de ameaças e pelo apoio em corrigir o rumo do Carcará Threat Poker.

Ao amigo Felipe Simão, que sempre representou uma grande referência de liderança, sou grato por cada conselho, pelo apoio no mestrado e pelos exemplos inspiradores.

Ao Juliano, agradeço pela generosidade em dividir experiências e aprendizados a respeito de metodologias ágeis, que enriqueceram este trabalho.

Minha gratidão ao CESAR pela oportunidade de realizar este mestrado por meio de uma bolsa de estudos, que possibilitou não apenas meu crescimento profissional, mas também a produção de conhecimento com impacto positivo para a sociedade.

Expresso minha profunda gratidão ao TJPE pela oportunidade de realizar este mestrado, viabilizado pelo apoio institucional que permitiu não apenas o meu aperfeiçoamento técnico e acadêmico.

Por fim, expresso meus mais sinceros agradecimentos a todas as pessoas que, de diferentes formas, estiveram ao meu lado ao longo desta caminhada.

"Even though several approaches to secure software development have been proposed in the literature, current literature does not offer an unambiguous and comprehensive solution to secure software development with agile methods, suitable for businesses with limited budgets."(Mihelič et al., 2024)
Tradução: Embora várias abordagens de desenvolvimento seguro tenham sido propostas, a literatura atual não oferece uma solução clara e abrangente para o desenvolvimento de software seguro com métodos ágeis, adequada para empresas com orçamentos limitados.

RESUMO

A adoção de práticas preventivas de segurança em ambientes ágeis permanece limitada, apesar de recomendações presentes em frameworks como NIST SSDF e OWASP SAMM. Estudos apontam barreiras recorrentes, incluindo complexidade operacional, resistência cultural e ausência de mecanismos objetivos para priorização e rastreabilidade de riscos no backlog.

Este trabalho tem como objetivo propor e avaliar uma abordagem pragmática para integrar a modelagem de ameaças ao planejamento ágil, preservando a estrutura do Scrum e evitando a criação de novos papéis ou cerimônias. Para isso, foi conduzida uma Revisão Rápida da Literatura (2020–2025) e, em seguida, um estudo de caso qualitativo em um projeto real de desenvolvimento de software.

Como resultado, é proposto o método **Carcará Agile Threat Modeling (CATM)**, estruturado em: (i) *Atividades de Segurança Proativas (ASP)*, unidades mínimas de trabalho de segurança prioritizáveis por risco e esforço; e (ii) o *Carcará Threat Poker*, instrumento colaborativo apoiado por IA consultiva para apoiar a identificação e a priorização de ameaças no nível de histórias de usuário, com base em referências como OWASP Top 10, CWE, Cheat Sheets e CVSS.

O nome CARCARÁ faz referência à ave típica do Nordeste brasileiro reconhecida por sua capacidade de observação estratégica e adaptação ao ambiente. A metáfora busca representar a postura vigilante e antecipatória proposta pelo método, no qual riscos são identificados e tratados antes de se materializarem em vulnerabilidades no software. Dessa forma, o nome simboliza a atuação preventiva e contínua sobre ameaças no contexto do desenvolvimento ágil.

A avaliação empírica indica que o CATM viabiliza a explicitação de riscos e a derivação de decisões de segurança incorporadas aos critérios de aceitação e ao backlog, mantendo aderência ao fluxo do Scrum. As limitações observadas incluem necessidade de calibração inicial do instrumento, requisitos de governança para uso da IA e dependência de integração com ferramentas de gestão de backlog.

Este trabalho contribui ao operacionalizar o *shift-left security* no planejamento ágil e ao oferecer evidências empíricas de uma integração viável da modelagem de ameaças em contextos ágeis.

Palavras-chave: Desenvolvimento seguro de software; Métodos ágeis; DevSecOps; Shift-left; Modelagem de ameaças; Segurança da informação.

ABSTRACT

The adoption of preventive software security practices in agile environments remains limited, despite recommendations from frameworks such as NIST SSDF and OWASP SAMM. The literature reports recurring barriers, including operational complexity, cultural resistance, and the lack of objective mechanisms for risk prioritization and traceability within the backlog.

This work aims to propose and evaluate a pragmatic approach to integrate threat modeling into agile planning while preserving the Scrum structure and avoiding new roles or ceremonies. To this end, a Rapid Literature Review (2020–2025) was conducted, followed by a qualitative case study in a real-world software project.

As a result, the **Carcará Agile Threat Modeling (CATM)** method is proposed, structured around: (i) *Proactive Security Activities* (ASP), minimal security work items prioritized by risk and effort; and (ii) the *Carcará Threat Poker*, a collaborative instrument supported by consultative AI to assist threat identification and prioritization at the user-story level, grounded in references such as OWASP Top 10, CWE, Cheat Sheets, and CVSS.

Empirical evaluation indicates that CATM enables risks to be made explicit and translated into security decisions incorporated into acceptance criteria and the sprint backlog, while remaining aligned with the Scrum flow. Observed limitations include the need for initial calibration, governance requirements for AI use, and dependency on integration with backlog management tools.

This work contributes by operationalizing *shift-left security* in agile planning and by providing empirical evidence of a feasible lightweight threat modeling integration in agile contexts.

Keywords: Secure software development, Agile methods, DevSecOps, Shift left, Threat modeling, Information security.

LISTA DE ILUSTRAÇÕES

Figura 1 – Estrutura adaptada do Scrum com papéis especializados para apoio à qualidade e à segurança. Fonte: Adaptado de Ahmad, Gustavsson e Saeeda (2023).	25
Figura 2 – Considerações organizacionais para fomentar a adoção de práticas de segurança de software por desenvolvedores. Fonte: Adaptado de Larios-Vargas et al. (2023).	27
Figura 3 – Fluxo de etapas da modelagem de ameaças segundo a abordagem STRIDE. Fonte: Shostack (2014).	30
Figura 4 – Desenho metodológico da pesquisa	39
Figura 5 – Integração da modelagem de ameaças às cerimônias do Scrum	73

LISTA DE QUADROS

Quadro 1 – Estudos incluídos na Revisão Rápida da Literatura	43
Quadro 2 – Artigos selecionados na Rapid Review organizados por categoria temática .	44
Quadro 2 – Comparação entre abordagens tradicionais de modelagem de ameaças e o método CARCARÁ	57
Quadro 3 – Evidências empíricas por cerimônia (Sprint 17)	68
Quadro 4 – Histórias planejadas e cobertura da modelagem de ameaças (Sprint 17) . .	69
Quadro 5 – Histórias de usuário analisadas e Atividade de Segurança Proativa (ASP)s geradas na Sprint 17	70
Quadro 6 – Evolução dos critérios de aceitação após a modelagem de ameaças	71
Quadro 7 – Ameaças identificadas, classificação e esforço de mitigação (Sprint 17) . .	71
Quadro 8 – Impactos da modelagem de ameaças no fluxo ágil por história de usuário .	73

LISTA DE TABELAS

Tabela 1 – Escala de avaliação do fator Risco (R)	49
Tabela 2 – Escala de avaliação do fator Esforço de Mitigação (EM)	50
Tabela 3 – Indicadores objetivos utilizados na avaliação do CATM	62
Tabela 4 – Síntese dos resultados observados na aplicação do CATM (Sprint 17) . . .	68
Tabela 5 – ASPs criadas durante o planejamento da Sprint 17	103
Tabela 6 – Status das ASPs avaliadas na Sprint Review da Sprint 17	108

LISTA DE ABREVIATURAS E SIGLAS

API Application Programming Interface 68–70

ASP Atividade de Segurança Proativa 10, 15, 16, 39, 46–48, 50–55, 59–63, 66, 68–70, 72–75, 77, 78, 82, 87

BSIMM Building Security In Maturity Model 18, 23

CAMS Cultura, Automação, Métricas e Compartilhamento 26

CASE Continuous Adaptive Secure Enterprise 19

CATM Carcará Agile Threat Modeling 15, 38, 39, 46, 47, 51, 53, 57–62, 64, 66, 67, 69, 72, 74, 76, 77, 79–82, 84, 87

CI/CD Continuous Integration and Continuous Delivery 36

CTP Carcará Threat Poker 15, 46, 47, 51–53, 55, 56, 59, 60, 62, 63, 69, 73, 74, 78, 82

CVSS Common Vulnerability Scoring System 30, 51, 52, 54

CWE Common Weakness Enumeration 30, 31, 71, 81

DASP Driving the Adoption of Software Security Practices 26, 32, 36, 48

DevOps Desenvolvimento e Operações 26, 66

DevSecOps Desenvolvimento, Segurança e Operações 22, 26, 28, 32, 34–36, 40–42, 48, 87

DFD Diagrama de Fluxo de Dados 29, 31

LLM Large Language Models 47

MNI Modelo Nacional de Interoperabilidade 72, 73

NIST National Institute of Standards and Technology 18, 22, 41, 48

OWASP SAMM OWASP Software Assurance Maturity Model 18, 23, 41, 48

PO Product Owner 66

SAFe Scaled Agile Framework 51, 74

SDL Security Development Lifecycle 22

SDLC Ciclo de Vida de Desenvolvimento de Software 18, 35

SSDF Secure Software Development Framework 18, 22, 23

STRIDE Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege 29

TJPE Tribunal de Justiça de Pernambuco 66

UTF-8 Formato de Transformação Unicode de 8 bits 73, 74

WSJF Weighted Shortest Job First 49, 74

SUMÁRIO

1	INTRODUÇÃO	18
1.1	INTRODUÇÃO	18
1.2	PERGUNTAS DE PESQUISA	19
1.3	OBJETIVOS	20
1.3.1	Objetivo Geral	20
1.3.1.1	<i>Objetivos específicos</i>	20
1.4	ORGANIZAÇÃO	20
2	FUNDAMENTAÇÃO TEÓRICA	22
2.1	SEGURANÇA NO CICLO DE VIDA DO DESENVOLVIMENTO DE SOFTWARE	22
2.2	ADOÇÃO DE FRAMEWORKS DE DESENVOLVIMENTO SEGURO	23
2.3	INTEGRAÇÃO DA SEGURANÇA EM MÉTODOS ÁGEIS	24
2.4	PRÁTICAS DEVSECOPS E HABILITADORES CULTURAIS	26
2.5	MODELAGEM DE AMEAÇAS E SISTEMAS DE CLASSIFICAÇÃO DE VULNERABILIDADES	28
2.6	GAMIFICAÇÃO E CONSCIENTIZAÇÃO EM SEGURANÇA	31
2.7	INTEGRAÇÃO COM GESTÃO E MONITORAMENTO CONTÍNUO	32
2.8	TRABALHOS RELACIONADOS	34
2.8.1	Segurança em métodos ágeis e DevSecOps	34
2.8.2	Modelagem de ameaças no ciclo de vida do software	35
2.8.3	Automação, pipelines e limitações das abordagens existentes	36
2.8.4	Engajamento humano e conscientização em segurança	36
3	METODOLOGIA	38
3.0.1	Desenho metodológico da pesquisa	38
3.1	RAPID REVIEW	39
3.1.1	Escopo e atalhos metodológicos	40
3.1.2	Estratégia de busca	40
3.1.3	Critérios de inclusão e exclusão	41
3.1.4	Processo de seleção	41
3.1.4.1	<i>Limitações da Revisão Rápida</i>	45

3.2	DERIVAÇÃO DO MÉTODO PROPOSTO: Carcará Agile Threat Modeling (CATM) A PARTIR DA LITERATURA	46
3.2.1	Atividades de Segurança Proativas (ASP)	47
3.2.1.1	<i>Exemplo de aplicação dos critérios de risco e esforço</i>	50
3.2.2	Mecânica do Carcará Threat Poker	51
3.2.3	Exemplo ilustrativo de aplicação do Carcará Threat Poker (CTP) e ASP	53
3.2.3.0.1	<i>História de usuário</i>	53
3.2.3.0.2	<i>Apoio inicial da IA na identificação de ameaças</i>	53
3.2.3.0.3	<i>Discussão colaborativa orientada pelas sugestões</i>	54
3.2.3.0.4	<i>Atribuição de valores e cálculo do ASP</i>	54
3.2.3.0.5	<i>Conversão em Atividade de Segurança Proativa</i>	55
3.2.3.0.6	<i>Resultado do processo ilustrativo</i>	55
3.2.4	Posicionamento do CATM em relação a abordagens tradicionais . .	56
3.3	ESTUDO DE CASO QUALITATIVO	57
3.3.1	Delineamento do Estudo de Caso	58
3.3.2	Aplicação do CATM no estudo de caso	58
3.3.3	Procedimento de instrução inicial do método	59
3.3.4	Coleta de dados	59
3.3.5	Papel do pesquisador	60
3.3.6	Avaliação do método CATM	60
3.3.6.1	<i>Critérios de avaliação</i>	61
3.3.6.2	<i>Como os critérios serão aplicados</i>	61
3.3.6.3	<i>Indicadores objetivos de avaliação</i>	62
3.3.6.4	<i>Tratamento e análise dos dados</i>	62
3.4	LIMITAÇÕES DA PESQUISA	63
4	RESULTADOS	66
4.1	CONTEXTO DO ESTUDO DE CASO	66
4.2	RESULTADOS DO ESTUDO DE CASO	67
4.2.1	Síntese quantitativa da aplicação do CATM na Sprint 17	68
4.2.2	QP1 – Artefatos de segurança produzidos	69
4.2.3	QP2 – Decisões de segurança produzidas	70

4.3	QP3 – COMO A INTEGRAÇÃO DA MODELAGEM DE AMEAÇAS IMPACTA O FLUXO ÁGIL DE DESENVOLVIMENTO?	72
4.4	APLICABILIDADE DO MÉTODO EM OUTROS CONTEXTOS	74
5	DISCUSSÃO	76
5.1	INTEGRAÇÃO DA MODELAGEM DE AMEAÇAS AO PLANEJAMENTO ÁGIL	76
5.2	ARTEFATOS LEVES E RASTREABILIDADE DAS DECISÕES DE SEGURANÇA	77
5.3	CARCARÁ THREAT POKER COMO INSTRUMENTO DE APOIO À PERCEPÇÃO DE RISCOS	77
5.4	LIMITAÇÕES DAS ATIVIDADES DE SEGURANÇA PROATIVAS (ASP) . .	78
5.5	EXPLICITAÇÃO E FORMALIZAÇÃO DAS DECISÕES DE SEGURANÇA .	79
5.6	IMPLICAÇÕES PARA EQUIPES SEM ESPECIALISTAS EM SEGURANÇA	79
5.6.0.1	<i>Esforço cultural na adoção do CATM</i>	79
5.7	CONTRIBUIÇÕES DO TRABALHO	80
5.7.1	Contribuições para a academia	80
5.7.2	Contribuições para a indústria	81
5.7.3	Contribuições para a sociedade	81
6	AMEAÇAS À VALIDADE	82
6.1	VALIDADE DE CONSTRUÇÃO	82
6.2	VALIDADE INTERNA	82
6.3	VALIDADE EXTERNA	83
6.4	VALIDADE DE CONFIABILIDADE	83
7	CONCLUSÃO	85
	REFERÊNCIAS	88
	APÊNDICE A – ESTRUTURAS DE SAÍDA EM JSON DO CARCARÁ THREAT POKER	91
	APÊNDICE B – PROMPTS UTILIZADOS NO CARCARÁ THREAT POKER	94
	APÊNDICE C – INSTRUMENTO DE COLETA E REGISTRO DO ESTUDO DE CASO	97
	APÊNDICE D – REGISTROS EMPÍRICOS DA SPRINT 17 — SPRINT PLANNING	101

APÊNDICE E – REGISTROS EMPÍRICOS DA SPRINT 17 —	
DAILY SCRUM	105
APÊNDICE F – REGISTROS EMPÍRICOS DA SPRINT 17 —	
SPRINT REVIEW	107
APÊNDICE G – REGISTROS EMPÍRICOS DA SPRINT 17 —	
SPRINT RETROSPECTIVE	110
APÊNDICE H – RETORNO DO THREAT POKER — HISTÓRIA	
US01	113
APÊNDICE I – RETORNO DO THREAT POKER — HISTÓRIA	
US02	114

1 INTRODUÇÃO

1.1 INTRODUÇÃO

A crescente complexidade dos sistemas e a sofisticação das ameaças cibernéticas impõem desafios cada vez maiores ao desenvolvimento de software. Nikolov e Aleksieva-Petrova (2023) apontam que as ameaças emergentes levaram a um aumento de 600% no cibercrime desde o início da pandemia, com criminosos utilizando táticas sofisticadas como *cross-site scripting* (XSS) e injeção de SQL. Esse movimento também se reflete nos ataques à cadeia de suprimentos, que cresceram 430% em apenas um ano (Hastings; Walcott, 2022). Falhas de segurança colocam as organizações sob pressão para integrar práticas de desenvolvimento seguro em todas as etapas do ciclo de vida do software (Wee; Kudriavtseva; Gadyatskaya, 2024). Como resposta a essa necessidade, surgiram frameworks como o Secure Software Development Framework (SSDF) do National Institute of Standards and Technology (NIST), o OWASP Software Assurance Maturity Model (OWASP SAMM) e o Building Security In Maturity Model (BSIMM), que orientam as equipes na adoção de práticas estruturadas. Ainda assim, muitas organizações preferem personalizar seus próprios frameworks, buscando maior flexibilidade e alinhamento com seus processos internos (Wee; Kudriavtseva; Gadyatskaya, 2024).

Entre as práticas recomendadas por esses frameworks, destaca-se a **modelagem de ameaças**, uma atividade sistemática cujo objetivo é identificar, analisar e priorizar potenciais ameaças de segurança ainda nas fases iniciais do desenvolvimento. De acordo com Phanireddy (2025), a modelagem de ameaças permite analisar a arquitetura da aplicação, seus fluxos de dados e possíveis vetores de ataque a partir da perspectiva de um adversário, viabilizando a definição antecipada de medidas de mitigação antes que vulnerabilidades sejam exploradas em ambientes produtivos. Ao antecipar cenários de abuso e falhas estruturais, essa atividade contribui para a redução de retrabalho e custos de correção, além de fortalecer a postura de segurança ao longo do ciclo de vida do software.

Mihelič et al. (2024) destacam que atividades de segurança que demandam esforço adicional, como a modelagem de ameaças, entram em conflito com a velocidade de entregas dos métodos ágeis, por serem percebidas como complexas e lentas, especialmente no contexto de pequenas e médias empresas. Ainda assim, a literatura reconhece a modelagem de ameaças como uma prática fundamental. Wicaksono et al. (2024) a posicionam como uma atividade proativa nas fases de planejamento e design do Ciclo de Vida de Desenvolvimento de Software (SDLC).

De forma semelhante, Bekturova et al. (2023) a integram como um passo importante em seu modelo de desenvolvimento seguro, baseado na perspectiva de um defensor contra um atacante. Já Joshi (2024) introduzem o framework Continuous Adaptive Secure Enterprise (CASE), que também incorpora a modelagem de ameaças desde a fase de planejamento e requisitos. Esse contraste entre relevância técnica e baixa adoção prática indica uma lacuna recorrente na integração efetiva da modelagem de ameaças em contextos ágeis.

Entre os métodos ágeis amplamente adotados na indústria, destaca-se o Scrum, um framework de gestão de projetos que organiza o desenvolvimento em ciclos iterativos e incrementais chamados *sprints*, estruturados a partir de um *product backlog* priorizado. O Scrum foi concebido como um framework leve para lidar com problemas complexos, priorizando entregas frequentes, transparência e adaptação contínua. Entretanto, sua ênfase em velocidade e simplicidade pode dificultar a incorporação sistemática de práticas de segurança que exigem análise adicional, como a modelagem de ameaças. Nesse contexto, surge a necessidade de investigar formas de integrar atividades preventivas de segurança ao fluxo natural do Scrum, evitando a criação de novos papéis ou cerimônias e preservando a dinâmica ágil do processo.

O fator humano também se revela um elo central para a adoção de práticas seguras, conforme observado por Larios-Vargas et al. (2023). Mesmo com acesso a ferramentas, treinamentos e diretrizes, vulnerabilidades continuam a ser introduzidas no código, geralmente em função da pressão por entregas rápidas, do baixo engajamento ou da ausência de uma cultura de segurança consolidada. Além disso, Wee, Kudriavtseva e Gadyatskaya (2024) ressaltam a complexidade cognitiva envolvida na aplicação dessas práticas: Observa-se uma lacuna de competência operacional em que a complexidade cognitiva das técnicas formais de modelagem de ameaças excede a prontidão técnica imediata das equipes, resultando na negligência da prática em prol da cadência de entrega.

1.2 PERGUNTAS DE PESQUISA

Este trabalho será guiado pela seguinte questão geral de pesquisa:

De que forma a modelagem pode contribuir com o processo de desenvolvimento ágil do estudo de caso apresentado?

- **QP1:** Quais artefatos de segurança são produzidos a partir da aplicação da modelagem de ameaças ao longo do ciclo de desenvolvimento?

- **QP2:** Quais decisões de segurança são produzidos a partir da aplicação da modelagem de ameaças ao longo do ciclo de desenvolvimento?
- **QP3:** Quais mudanças no fluxo de desenvolvimento são observadas após a introdução da modelagem de ameaças no estudo de caso?

1.3 OBJETIVOS

1.3.1 Objetivo Geral

Propor e avaliar uma adaptação leve do framework Scrum que incorpore atividades de modelagem de ameaças ao fluxo de desenvolvimento ágil, observando seus efeitos ao longo do ciclo de desenvolvimento por meio de um estudo de caso qualitativo.

1.3.1.1 *Objetivos específicos*

Os objetivos específicos desta pesquisa incluem:

- Analisar os artefatos e as decisões de segurança produzidos a partir da aplicação da modelagem de ameaças ao longo do ciclo de desenvolvimento.
- Examinar as mudanças observadas no fluxo de desenvolvimento após a introdução da adaptação proposta.
- Observar os efeitos da aplicação da modelagem de ameaças ao longo do ciclo de desenvolvimento no contexto do estudo de caso.
- Descrever como a modelagem de ameaças passa a ser realizada dentro das cerimônias do Scrum, em especial na reunião de planejamento.

1.4 ORGANIZAÇÃO

Este trabalho está organizado da seguinte forma. O Capítulo 2 apresenta a fundamentação teórica, abordando conceitos relacionados à segurança no desenvolvimento de software, DevSecOps, modelagem de ameaças e práticas ágeis. O Capítulo 3 descreve a metodologia adotada na pesquisa, incluindo a Revisão Rápida da Literatura e o delineamento do estudo de caso qualitativo, bem como os procedimentos de coleta e análise dos dados. O Capítulo 4 apresenta os resultados da avaliação empírica do método *CARCARÁ Agile Threat Modeling*

(*CATM*), a partir da observação do estudo de caso, analisando os artefatos produzidos, as decisões de segurança e as mudanças no fluxo de desenvolvimento ágil. O Capítulo 5 discute os resultados obtidos à luz da literatura, destacando as contribuições do trabalho para a academia, a indústria e a sociedade, bem como suas implicações teóricas e práticas. O Capítulo 6 analisa as principais ameaças à validade da pesquisa, considerando aspectos internos, externos, de construção e de conclusão. Por fim, o Capítulo 7 apresenta as conclusões do trabalho, suas principais contribuições, limitações e direções para trabalhos futuros.

2 FUNDAMENTAÇÃO TEÓRICA

A fundamentação teórica deste trabalho apresenta os conceitos, práticas e desafios identificados na literatura a respeito de segurança no desenvolvimento de software, métodos ágeis (com foco em Scrum), Desenvolvimento, Segurança e Operações (DevSecOps), fatores culturais e organizacionais, gamificação e modelagem de ameaças. O objetivo é oferecer uma base conceitual consistente que sustente a análise do problema investigado e a proposição da abordagem apresentada nesta pesquisa.

2.1 SEGURANÇA NO CICLO DE VIDA DO DESENVOLVIMENTO DE SOFTWARE

A segurança da informação, quando tratada de forma tardia, tende a gerar retrabalho, aumento de custos e a persistência de vulnerabilidades em sistemas de software. Evidências empíricas indicam que o custo de correção de falhas cresce à medida que o ciclo de vida do software avança, uma vez que decisões tomadas nas fases de requisitos e arquitetura impactam diretamente a complexidade das correções posteriores (Núñez; Lindo; Rodríguez, 2020). Estudos de caso reforçam essa visão ao demonstrar reduções significativas no número de vulnerabilidades reportadas após a adoção de práticas sistemáticas de desenvolvimento seguro, indicando impacto direto na qualidade do produto e no custo de mitigação (Núñez; Lindo; Rodríguez, 2020).

Esse entendimento está presente em abordagens clássicas de desenvolvimento seguro. Guias como o Microsoft Security Development Lifecycle (SDL) defendem a incorporação sistemática de controles de segurança desde a concepção do software, com o objetivo de reduzir riscos técnicos e organizacionais ao longo do desenvolvimento (Microsoft, 2009). De forma complementar, modelos normativos reforçam essa abordagem. O NIST, por meio da publicação SP 800-218, define o SSDF, organizando práticas de segurança distribuídas ao longo do ciclo de vida, com foco na prevenção de vulnerabilidades (Souppaya et al., 2022).

A literatura recente consolida essa perspectiva sob o conceito de *shift-left security*. Dawoud et al. (2024) argumentam que deslocar atividades tradicionalmente realizadas ao final do processo, como auditorias e testes, para fases iniciais de planejamento e design contribui para aumentar a eficiência, reduzir retrabalho e mitigar riscos decorrentes de decisões arquiteturais inadequadas.

Além da prevenção, a segurança também é discutida como atributo de qualidade associado

à ciber-resiliência. Bolish et al. (2024) destacam que sistemas devem ser projetados não apenas para evitar vulnerabilidades, mas também para resistir, responder e se recuperar de incidentes, reforçando a necessidade de tratar a segurança como requisito não funcional em conjunto com desempenho, escalabilidade e confiabilidade.

Apesar do reconhecimento teórico e normativo da integração da segurança em todas as fases do ciclo de vida, a prática organizacional ainda apresenta resistências, especialmente em contextos pressionados por prazos e mudanças frequentes. Para esta pesquisa, esse cenário fundamenta a necessidade de mecanismos que viabilizem a integração antecipada da segurança em ambientes ágeis, reduzindo o custo e o retrabalho associados à correção tardia de vulnerabilidades.

2.2 ADOÇÃO DE FRAMEWORKS DE DESENVOLVIMENTO SEGURO

A preocupação em estruturar práticas de segurança ao longo do desenvolvimento resultou na criação de frameworks de referência que orientam organizações na redução de vulnerabilidades e na evolução de maturidade. Entre os mais reconhecidos na literatura estão o OWASP SAMM, o BSIMM e o SSDF, os quais organizam atividades de segurança de forma sistemática e distribuída ao longo do ciclo de vida do software.

Embora robustos, estudos indicam que a adoção integral desses frameworks encontra barreiras recorrentes. Wee, Kudriavtseva e Gadyatskaya (2024) apontam que, embora as organizações reconheçam o valor dessas referências, elas frequentemente as percebem como complexas e pouco aderentes às realidades de equipes ágeis, pressionadas por entregas rápidas e mudanças constantes. Como consequência, práticas tendem a ser adaptadas ou simplificadas. Esse movimento, embora necessário, envolve riscos e trade-offs: a ausência de diretrizes claras pode resultar em inconsistências e perda de efetividade (Núñez; Lindo; Rodríguez, 2020), enquanto abordagens excessivamente rígidas tornam-se inviáveis em pequenas e médias organizações, nas quais flexibilidade e incrementalidade são condições relevantes para viabilizar a adoção (Mihelič et al., 2024).

Em síntese, a literatura indica que frameworks consolidados constituem fontes valiosas de princípios e práticas de segurança, mas que sua aplicação prática demanda adaptações ao contexto organizacional, especialmente em cenários ágeis e com restrição de recursos. Essa tensão entre robustez conceitual e viabilidade operacional constitui um desafio recorrente para a integração efetiva da segurança ao desenvolvimento de software.

2.3 INTEGRAÇÃO DA SEGURANÇA EM MÉTODOS ÁGEIS

Metodologias ágeis, como o Scrum, priorizam entregas incrementais, ciclos curtos e feedback contínuo. Entretanto, a ênfase em velocidade pode entrar em tensão com atividades de segurança quando estas são percebidas como etapas adicionais ou externas ao fluxo de trabalho. Nesse cenário, organizações frequentemente tratam a segurança como uma fase separada ou posterior ao desenvolvimento, o que gera atritos entre times de desenvolvimento e segurança, conforme discutido por Dawoud et al. (2024).

O *Scrum Guide* define o Scrum como um framework leve para lidar com problemas complexos por meio de entregas incrementais e inspeção contínua (Schwaber; Sutherland, 2020). Seus papéis, eventos e artefatos foram concebidos para maximizar transparência, inspeção e adaptação, formando um fluxo empírico que pode servir como base para integrar práticas transversais, como segurança. Em particular, o *Product Backlog* concentra requisitos e decisões técnicas, e eventos como o *Sprint Planning* e a *Retrospective* estabelecem momentos formais para inspeção e ajuste do processo, criando oportunidades naturais para discutir riscos sem a necessidade de introduzir cerimônias paralelas.

Uma linha de pesquisa na literatura propõe integrar a segurança ao Scrum por meio da criação de papéis especializados. Ahmad, Gustavsson e Saeeda (2023) sugerem funções como *Product Guardian* e *Security Guardians*, que atuam como facilitadores da qualidade e da segurança no processo de desenvolvimento, com o objetivo de reduzir a sobrecarga cognitiva dos desenvolvedores e aumentar a consistência das decisões relacionadas à segurança.



Figura 1 – Estrutura adaptada do Scrum com papéis especializados para apoio à qualidade e à segurança.
Fonte: Adaptado de Ahmad, Gustavsson e Saeeda (2023).

Apesar dos benefícios potenciais, a literatura aponta limitações práticas associadas a esse tipo de abordagem. Mihelič et al. (2024) observam que a introdução de novos papéis e estruturas formais pode ser inviável em organizações com recursos limitados, em função de restrições de custo, disponibilidade de pessoal e maturidade organizacional. Nesses contextos, práticas enxutas e incrementais tendem a apresentar maior viabilidade operacional, reduzindo fricção e custo de adoção.

Outra abordagem recorrente identificada na literatura consiste na incorporação de discussões de segurança em cerimônias já existentes do Scrum. Akbar e AlSanad (2025) indicam que eventos como o *Sprint Planning*, a *Sprint Review* e a *Retrospective* podem ser utilizados para discutir riscos, revisar decisões e ajustar o processo, criando um espaço mais orgânico para a segurança sem a necessidade de eventos adicionais.

Ainda assim, resistências culturais permanecem como uma barreira relevante à integração efetiva da segurança. Larios-Vargas et al. (2023) demonstram que fatores comportamentais e motivacionais influenciam diretamente a adoção de práticas seguras. Esses achados sugerem

que a integração da segurança ao Scrum não depende apenas da definição de atividades ou estruturas formais, mas também da redução de fricção, da clareza sobre o valor da segurança e da criação de mecanismos que favoreçam o engajamento no fluxo de trabalho.

Dessa forma, a literatura apresenta diferentes alternativas para integrar segurança ao Scrum, como a criação de papéis especializados, a adoção de práticas enxutas e o uso de cerimônias existentes. No entanto, persistem lacunas quando se busca conciliar baixo custo, simplicidade e aderência ao fluxo ágil. Para este trabalho, essas lacunas fundamentam a investigação de uma abordagem que preserve a estrutura do Scrum, mas insira práticas de segurança diretamente no nível das histórias de usuário e no momento de planejamento e priorização do backlog.

2.4 PRÁTICAS DEVSECOPS E HABILITADORES CULTURAIS

O movimento Desenvolvimento e Operações (DevOps) surgiu com o objetivo de reduzir a distância entre desenvolvimento e operações por meio de automação, integração contínua e entrega frequente de software. Nesse contexto, o DevSecOps amplia esse paradigma ao incorporar a segurança como responsabilidade compartilhada, evitando que ela seja tratada como um gargalo ou etapa externa ao fluxo de desenvolvimento. Aljohani e Alqahtani (2023) destacam que essa integração desloca a segurança de uma função centralizada para uma prática cotidiana das equipes de engenharia.

Entretanto, a literatura ressalta que a adoção do DevSecOps não se limita à introdução de ferramentas ou automações em pipelines. Akbar e AlSanad (2025) observam que iniciativas focadas exclusivamente em soluções técnicas tendem a apresentar resultados limitados quando não são acompanhadas por mudanças culturais, organizacionais e comportamentais. Nessas situações, a segurança pode continuar sendo percebida como um obstáculo à produtividade, gerando resistência por parte dos desenvolvedores.

Diversos autores apontam a cultura organizacional como um dos principais habilitadores do DevSecOps. Akbar e AlSanad (2025) discutem o modelo Cultura, Automação, Métricas e Compartilhamento (CAMS) e enfatizam que a internalização da segurança no cotidiano das equipes é condição essencial para sua adoção sustentável. Cultura, nesse sentido, envolve valores, práticas, incentivos, comunicação e formas de tomada de decisão relacionadas à segurança.

Essa dimensão cultural é explorada de forma sistemática por Larios-Vargas et al. (2023), que propõem o framework Driving the Adoption of Software Security Practices (DASP). Os autores organizam sete considerações que organizações e *stakeholders* devem observar para fomentar a

adoção de práticas de segurança por desenvolvedores, abrangendo desde a construção de uma cultura organizacional de segurança até o fornecimento de suporte cognitivo e informações contextuais relevantes.

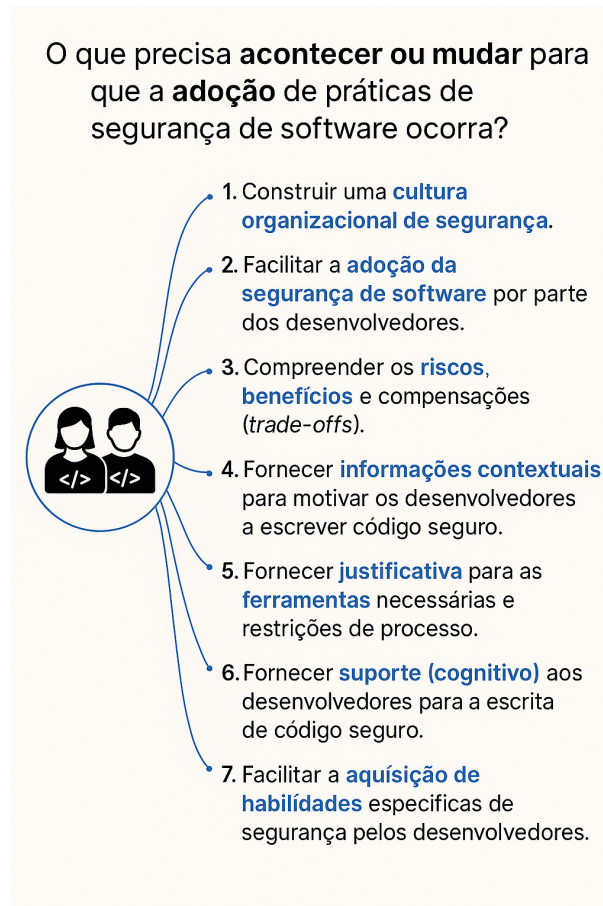


Figura 2 – Considerações organizacionais para fomentar a adoção de práticas de segurança de software por desenvolvedores. Fonte: Adaptado de Larios-Vargas et al. (2023).

Um aspecto central destacado por esse framework é o reconhecimento de que a segurança impõe custos cognitivos aos desenvolvedores. Larios-Vargas et al. (2023) argumentam que a necessidade de compreender ameaças, avaliar impactos e decidir entre alternativas de mitigação adiciona complexidade ao processo de desenvolvimento, especialmente em equipes sem especialistas dedicados. Quando esse esforço não é adequadamente apoiado, decisões de segurança tendem a ser postergadas, simplificadas ou tratadas de forma implícita.

Nesse sentido, práticas de segurança eficazes devem oferecer apoio cognitivo contextualizado, reduzindo fricção e facilitando a tomada de decisão no momento em que o trabalho é realizado. Isso inclui o fornecimento de informações acionáveis, linguagem acessível e mecanismos que auxiliem os desenvolvedores a compreender riscos e consequências sem interromper o fluxo ágil.

Além dos aspectos culturais e cognitivos, a literatura também ressalta a importância de

métricas e mecanismos de monitoramento contínuo para a consolidação do DevSecOps. Akbar e AlSanad (2025) apontam que métricas tornam a segurança observável, permitindo acompanhar sua evolução, priorizar esforços e retroalimentar o processo de melhoria contínua. Na ausência desses mecanismos, a segurança tende a ser tratada de forma episódica e reativa.

Para esta pesquisa, esses achados são particularmente relevantes, pois indicam que a efetividade da segurança no desenvolvimento ágil depende menos da introdução de novos papéis ou ferramentas e mais da capacidade de integrar a segurança ao fluxo existente de trabalho, reduzindo carga cognitiva, aumentando a clareza sobre riscos e transformando decisões de segurança em ações concretas e rastreáveis.

2.5 MODELAGEM DE AMEAÇAS E SISTEMAS DE CLASSIFICAÇÃO DE VULNERABILIDADES

A modelagem de ameaças é reconhecida na literatura como uma prática central do desenvolvimento seguro, por permitir a identificação, análise e priorização de riscos antes da exploração de vulnerabilidades em ambientes de produção. Diferentemente de abordagens reativas, que dependem de auditorias e testes realizados após a implementação, a modelagem de ameaças adota uma postura proativa, antecipando cenários de abuso e vetores de ataque ainda nas fases iniciais do desenvolvimento (Phanireddy, 2025).

Segundo Phanireddy (2025), a modelagem de ameaças consiste em uma análise sistemática da arquitetura, dos fluxos de dados e dos pontos de interação de um sistema, conduzida sob a perspectiva de um potencial adversário. Essa abordagem permite transformar riscos abstratos em decisões técnicas concretas, viabilizando a definição antecipada de controles de segurança e reduzindo o custo associado a correções tardias. Essa característica alinha-se ao princípio de *shift-left security*, ao deslocar a análise de riscos para momentos em que decisões estruturais ainda podem ser ajustadas com menor impacto (Dawoud et al., 2024).

A literatura associa de forma recorrente a modelagem de ameaças às fases iniciais do ciclo de vida do desenvolvimento de software. Wicaksono et al. (2024) posicionam essa prática como estratégica no planejamento e no design, destacando que escolhas arquiteturais inadequadas podem introduzir vulnerabilidades difíceis de mitigar em etapas posteriores. Em abordagens tradicionais, a modelagem tende, portanto, a ocorrer de forma concentrada no início do projeto, vinculada à definição de requisitos e à arquitetura do sistema.

Historicamente, técnicas consolidadas estruturam a modelagem de ameaças por meio de

categorias e artefatos formais. Um dos modelos mais difundidos é o Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege (STRIDE), proposto pela Microsoft, que organiza a análise em seis categorias de ameaça (Microsoft, 2006):

- **Spoofing:** falsificação de identidade;
- **Tampering:** manipulação ou alteração indevida de dados;
- **Repudiation:** negação de autoria ou responsabilidade sobre ações realizadas;
- **Information Disclosure:** exposição não autorizada de informações;
- **Denial of Service:** indisponibilização de serviços ou recursos;
- **Elevation of Privilege:** obtenção indevida de privilégios elevados.

A aplicação do *STRIDE* é comumente realizada a partir de Diagrama de Fluxo de Dados (DFD), que representam graficamente a circulação de dados entre atores externos, processos, armazenamentos e interfaces do sistema. O DFD abstrai a lógica interna da aplicação e enfatiza os pontos de interação, servindo como base para a identificação sistemática de ameaças associadas a cada elemento do modelo (Shostack, 2014).

Como ilustrado na Figura 3, o processo de modelagem de ameaças segue um conjunto de etapas estruturadas, que incluem a identificação de ativos, a análise de superfícies de ataque, a categorização de ameaças e a definição de contramedidas. Esse fluxo fornece uma base metodológica consolidada para técnicas como o *STRIDE*, reforçando seu caráter sistemático e replicável (Shostack, 2014; Phanireddy, 2025).

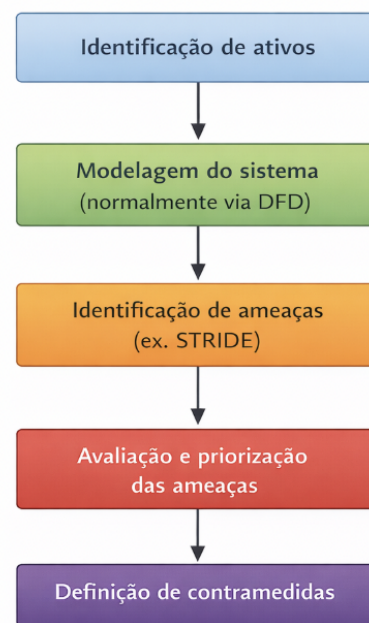


Figura 3 – Fluxo de etapas da modelagem de ameaças segundo a abordagem STRIDE. Fonte: Shostack (2014).

Apesar de sua relevância conceitual, evidências empíricas indicam limitações significativas na adoção prática da modelagem de ameaças em contextos ágeis e DevSecOps. Nikolov e Aleksieva-Petrova (2023) observam que essa prática é frequentemente percebida como complexa, lenta e desconectada do fluxo cotidiano de desenvolvimento, o que contribui para sua negligência ou aplicação pontual em fases tardias do projeto, reduzindo seu potencial preventivo.

Com o objetivo de mitigar essas dificuldades, estudos recentes propõem reformulações conceituais da prática. Bekturova et al. (2023), por exemplo, apresentam o modelo *defender-attacker*, que estrutura a análise de ameaças a partir de duas perspectivas complementares: a do atacante, focada em vetores de exploração e cenários de abuso, e a do defensor, orientada à identificação de controles e mecanismos de proteção. Essa abordagem busca tornar o raciocínio de segurança mais intuitivo e alinhado ao cotidiano de ataque e defesa.

No que se refere à priorização dos riscos identificados, a literatura destaca a importância de sistemas padronizados de classificação de vulnerabilidades. Aljohani e Alqahtani (2023) e Hastings e Walcott (2022) ressaltam o papel de mecanismos como o Common Vulnerability Scoring System (CVSS) e o Common Weakness Enumeration (CWE) na descrição, comunicação e priorização de achados de segurança. O CVSS fornece uma pontuação padronizada de severidade com base em fatores como complexidade do ataque, privilégios requeridos, escopo e impacto sobre confidencialidade, integridade e disponibilidade (Jiang; Zhang; Wang, 2022).

Já o CWE organiza uma taxonomia de fraquezas recorrentes de software, contribuindo para a compreensão de padrões estruturais de falhas e para ações preventivas durante o desenvolvimento (Verendel; McGraw, 2023).

Além dos DFDs e das categorias do *STRIDE*, a modelagem de ameaças pode se apoiar em uma variedade de artefatos complementares. Mauw e Oostdijk (2006) introduzem as árvores de ataque (*attack trees*) como representações hierárquicas de cenários de ameaça, nas quais um objetivo malicioso é decomposto em diferentes caminhos possíveis para sua concretização. Shostack (2014) também destacam o uso de tabelas de ameaça por elemento, matrizes de risco baseadas em impacto e probabilidade, bem como catálogos de ativos, atores e controles, ampliando a clareza e a comunicação entre diferentes perfis envolvidos no desenvolvimento.

Um ponto recorrente na literatura é que a modelagem de ameaças permanece, em grande parte, concentrada em momentos específicos do projeto. Em contextos ágeis orientados a histórias de usuário, essa característica pode dificultar a tradução dos riscos identificados em ações concretas ao longo das sprints. Nikolov e Aleksieva-Petrova (2023) e Mihelič et al. (2024) indicam que práticas de segurança desacopladas do fluxo ágil tendem a perder relevância prática, seja por restrições de tempo, seja por dificuldades de interpretação e execução pelos desenvolvedores.

Dessa forma, os estudos analisados apontam indícios de uma lacuna relacionada a abordagens que tratem a modelagem de ameaças como uma atividade contínua e acionável no ciclo ágil, especialmente quando aplicada no nível das histórias de usuário e integrada ao planejamento e à priorização do backlog. Essa lacuna fundamenta a motivação desta pesquisa, ao evidenciar a necessidade de mecanismos que tornem a modelagem de ameaças compreensível e operacionalizável no fluxo do Scrum, com resultados diretamente convertidos em ações de segurança gerenciáveis.

2.6 GAMIFICAÇÃO E CONSCIENTIZAÇÃO EM SEGURANÇA

A conscientização em segurança é amplamente reconhecida como um fator relevante para a redução de vulnerabilidades associadas a falhas humanas. No entanto, a literatura aponta que treinamentos tradicionais de segurança tendem a apresentar efetividade limitada quando são percebidos como excessivamente formais ou burocráticos, o que pode comprometer o engajamento dos participantes e a transferência do conhecimento para a prática cotidiana (Wee; Kudriavtseva; Gadyatskaya, 2024).

Nesse contexto, a gamificação emerge como uma alternativa para ampliar o envolvimento dos profissionais, ao incorporar elementos como desafios, recompensas e interação social em atividades de aprendizagem. Zhao et al. (2024) argumentam que jogos sérios podem aumentar a participação e favorecer a assimilação de conteúdos em ambientes corporativos, inclusive em contextos híbridos, aproximando os profissionais de temas que, em geral, despertam menor interesse ou são percebidos como complexos.

Além de seu potencial educativo, a gamificação é associada na literatura a processos de mudança cultural. O framework DASP destaca que fatores motivacionais e comportamentais exercem influência direta na adoção de práticas de segurança (Larios-Vargas et al., 2023), sugerindo que mecanismos motivacionais podem reduzir resistência e fricção no cotidiano das equipes de desenvolvimento. Nessa perspectiva, a gamificação pode atuar como facilitador da internalização de práticas seguras, ao tornar a segurança mais acessível e menos dissociada do fluxo de trabalho.

Apesar desses benefícios, observa-se que a maior parte das iniciativas relatadas na literatura concentra o uso da gamificação em programas formais de treinamento e conscientização. Há, portanto, espaço para investigar sua aplicação integrada ao fluxo de engenharia de software e às práticas ágeis, de modo a apoiar a adoção contínua de segurança no desenvolvimento.

Para este trabalho, essa perspectiva é relevante por indicar que mecanismos motivacionais podem contribuir para reduzir resistências culturais e favorecer a incorporação prática da segurança, especialmente quando inseridos em atividades recorrentes e alinhadas ao ritmo do desenvolvimento ágil.

2.7 INTEGRAÇÃO COM GESTÃO E MONITORAMENTO CONTÍNUO

A integração da segurança ao desenvolvimento de software não se limita à execução de controles técnicos isolados, mas envolve sua articulação com práticas de gestão, governança e monitoramento contínuo. A literatura indica que a efetividade das iniciativas de segurança está diretamente associada à capacidade das organizações de tornar riscos, decisões e ações técnicas explícitos, rastreáveis e passíveis de acompanhamento ao longo do ciclo de vida do software. Segundo Wicaksono et al. (2024), quando a segurança não é traduzida em artefatos e indicadores gerenciáveis, ela tende a permanecer desconectada dos processos de gestão, dificultando o monitoramento contínuo e a tomada de decisão.

No contexto de métodos ágeis e práticas de DevSecOps, essa integração assume relevância

particular, uma vez que decisões são tomadas de forma incremental e distribuída ao longo das sprints. Akbar e AlSanad (2025) destacam que a ausência de mecanismos de acompanhamento contínuo tende a tornar a segurança predominantemente reativa, com foco em correções pontuais, o que dificulta a consolidação de práticas preventivas. Nesse sentido, integrar a segurança à gestão implica garantir que riscos identificados, ações de mitigação e exceções sejam registrados, acompanhados e revisados de forma sistemática ao longo do tempo.

A literatura também aponta que métricas exercem papel central nesse processo. Aljohani e Alqahtani (2023) argumentam que práticas de segurança só se tornam sustentáveis quando seus resultados são observáveis, mensuráveis e conectados a objetivos de negócio. Métricas relacionadas à quantidade de riscos identificados, ações de mitigação priorizadas, riscos aceitos e pendências acumuladas permitem avaliar não apenas o estado técnico do sistema, mas também a maturidade do processo de segurança adotado pela organização.

Além disso, Hastings e Walcott (2022) ressaltam que o monitoramento contínuo é fundamental para lidar com riscos dinâmicos, como aqueles associados à cadeia de suprimentos de software e à evolução constante de dependências externas. Nesses cenários, decisões tomadas em uma sprint podem perder validade em ciclos posteriores, exigindo reavaliação periódica e visibilidade histórica das escolhas realizadas.

Sob a perspectiva da governança, Wicaksono et al. (2024) defendem que a segurança deve ser tratada como parte integrante da gestão do desenvolvimento, e não como responsabilidade exclusiva de áreas especializadas. Isso implica que decisões relacionadas à identificação, priorização e aceitação residual de riscos sejam registradas em artefatos acessíveis tanto às equipes quanto à gestão, possibilitando rastreabilidade e auditoria leve, compatível com ambientes ágeis.

Nesse contexto, observa-se uma convergência na literatura em torno da necessidade de mecanismos que conectem a identificação de riscos às estruturas já utilizadas para planejamento e acompanhamento do trabalho, como backlog, histórias de usuário e critérios de aceitação. Essa integração permite que a segurança seja acompanhada de forma contínua, sem a criação de fluxos paralelos de controle, reduzindo fricção e aumentando a aderência das equipes Akbar e AlSanad (2025).

Para este trabalho, essa perspectiva é relevante por fundamentar a importância de abordagens que transformem a modelagem de ameaças em insumos gerenciais, capazes de apoiar decisões ao longo das sprints. Ao integrar riscos, priorização e ações de segurança aos mecanismos de gestão já existentes no Scrum, estabelece-se a base conceitual para um monitoramento

contínuo da segurança alinhado ao ritmo incremental do desenvolvimento ágil.

2.8 TRABALHOS RELACIONADOS

Esta seção apresenta trabalhos da literatura que se relacionam diretamente com a proposta desta pesquisa, abordando a integração da segurança em métodos ágeis, a modelagem de ameaças no ciclo de vida do software, a automação em pipelines DevSecOps e os fatores humanos associados à adoção de práticas seguras. O objetivo é posicionar este trabalho em relação às contribuições existentes, destacando convergências, limitações e lacunas que fundamentam a abordagem investigada.

2.8.1 Segurança em métodos ágeis e DevSecOps

Diversos estudos investigam estratégias para integrar segurança a métodos ágeis e ambientes DevSecOps. Ahmad, Gustavsson e Saeeda (2023) propõem a adaptação do Scrum por meio da introdução de papéis especializados, como *Product Guardian* e *Security Guardians*, com o objetivo de reduzir a sobrecarga cognitiva dos desenvolvedores e aumentar a consistência das decisões de segurança. Essa abordagem reconhece a dificuldade de distribuir responsabilidades de segurança de forma homogênea em equipes ágeis e busca mitigá-la por meio da centralização parcial do conhecimento.

Em outra linha, Akbar e AlSanad (2025) defendem a incorporação de atividades de segurança em cerimônias ágeis já existentes, como *Sprint Planning* e *Retrospective*. Essa estratégia evita a criação de eventos adicionais e procura minimizar o impacto no fluxo de trabalho, alinhando-se à premissa de que a segurança deve ser integrada ao processo, e não tratada como uma atividade externa.

Apesar dessas contribuições, estudos empíricos indicam limitações relevantes. Mihelič et al. (2024) demonstram que a introdução de novos papéis ou estruturas formais pode ser inviável em pequenas e médias organizações, em função de restrições de custo, disponibilidade de pessoal e maturidade organizacional. Os autores observam que abordagens excessivamente estruturadas tendem a gerar resistência e dificultar a adoção contínua da segurança em ambientes ágeis.

De forma geral, embora esses trabalhos avancem na discussão sobre integração da segurança ao Scrum e ao DevSecOps, a maioria das propostas opera em nível macro, focando em papéis, cerimônias ou processos. Pouco se discute sobre a aplicação sistemática de práticas de segurança diretamente no nível das histórias de usuário, que constituem a principal unidade de planejamento

e priorização no Scrum. Essa lacuna é particularmente relevante para esta pesquisa, que investiga a integração da segurança no momento da definição e refinamento dos requisitos funcionais.

2.8.2 Modelagem de ameaças no ciclo de vida do software

A modelagem de ameaças é tradicionalmente apresentada como atividade estratégica nas fases iniciais do desenvolvimento. Phanireddy (2025) oferecem uma visão estruturada da prática, enfatizando a análise da arquitetura, dos fluxos de dados e dos pontos de interação do sistema como meio de antecipar riscos e orientar decisões de segurança. De forma semelhante, Wicaksono et al. (2024) posicionam a modelagem de ameaças como atividade crítica no planejamento e no design do SDLC, destacando seu papel na prevenção de vulnerabilidades estruturais.

Apesar de sua relevância conceitual, estudos empíricos apontam dificuldades significativas na adoção prática dessas abordagens. Nikolov e Aleksieva-Petrova (2023), ao analisar pipelines DevSecOps, observam que a modelagem de ameaças é frequentemente percebida como complexa, demorada e desconectada do fluxo ágil, o que leva à sua aplicação pontual ou à sua negligência. Essa percepção limita o potencial preventivo da prática, especialmente em contextos orientados a entregas incrementais.

Com o objetivo de reduzir a distância entre teoria e prática, Bekturova et al. (2023) propõem o modelo *defender-attacker*, que estrutura a modelagem de ameaças a partir de duas perspectivas complementares, buscando tornar o raciocínio de segurança mais intuitivo. Embora essa proposta represente um avanço conceitual, a modelagem de ameaças permanece como atividade técnica especializada, geralmente desvinculada do backlog ágil e das histórias de usuário que orientam o desenvolvimento.

De forma geral, os trabalhos analisados tratam a modelagem de ameaças como atividade concentrada em momentos específicos do projeto, como o início do desenvolvimento ou a definição da arquitetura. Poucos estudos exploram sua aplicação contínua ao longo do ciclo ágil, especialmente no nível das histórias de usuário. Essa limitação evidencia uma lacuna relevante que este trabalho busca endereçar ao investigar uma abordagem que operacionalize a modelagem de ameaças de forma recorrente e integrada ao fluxo Scrum.

2.8.3 Automação, pipelines e limitações das abordagens existentes

Outra vertente significativa da literatura concentra-se na automação de verificações de segurança em pipelines de Continuous Integration and Continuous Delivery (CI/CD). Aljohani e Alqahtani (2023) propõem um framework unificado para análise automatizada de segurança em ambientes DevSecOps, destacando o papel de ferramentas automatizadas na detecção precoce de vulnerabilidades. De forma complementar, Hastings e Walcott (2022) discutem a importância da verificação contínua de dependências de código aberto como mecanismo para mitigar riscos na cadeia de suprimentos de software.

Essas abordagens contribuem para aumentar a cobertura e a consistência das verificações de segurança, especialmente em fases posteriores do desenvolvimento. Contudo, seu foco permanece predominantemente reativo ou pós-implementação, atuando após a definição das funcionalidades e da arquitetura. Como resultado, riscos associados às decisões tomadas no nível dos requisitos e das histórias de usuário tendem a não ser explicitamente tratados por essas soluções.

Nesse sentido, observa-se que a automação em pipelines, embora essencial, não substitui práticas preventivas aplicadas nas fases iniciais do ciclo de vida. A literatura carece de propostas que conectem diretamente a análise de riscos aos artefatos ágeis de planejamento, como backlog e histórias de usuário, de forma sistemática e acionável, o que reforça a motivação desta pesquisa.

2.8.4 Engajamento humano e conscientização em segurança

Além dos aspectos técnicos, a literatura reconhece que fatores humanos exercem influência direta na adoção de práticas de segurança. Larios-Vargas et al. (2023), ao propor o framework DASP, demonstram que a efetividade da segurança de software está fortemente associada a fatores comportamentais, motivacionais e organizacionais, como clareza de papéis, incentivos sociais e apoio cognitivo ao desenvolvedor.

De forma complementar, Zhao et al. (2024) investigam o uso de jogos sérios e estratégias de gamificação em treinamentos corporativos, indicando aumento de engajamento e retenção de conhecimento. Esses resultados sugerem que abordagens motivacionais podem reduzir resistência cultural e tornar a segurança mais acessível aos profissionais.

Entretanto, observa-se que a maior parte dessas iniciativas permanece concentrada em programas de treinamento e conscientização, sem integração direta ao fluxo de desenvolvimento

ágil. Poucos trabalhos exploram a aplicação de mecanismos interativos ou gamificados no contexto da análise de requisitos e histórias de usuário, evidenciando uma lacuna que esta pesquisa busca explorar.

3 METODOLOGIA

Este capítulo descreve a metodologia adotada para a realização desta pesquisa. O desenho metodológico é composto por duas abordagens complementares:

- **Revisão Rápida da Literatura (*Rapid Review*)**: empregada para mapear o estado da arte e identificar lacunas relacionadas à integração de segurança em métodos ágeis e práticas *DevSecOps*;
- **Estudo de caso qualitativo**: planejado para investigar a aplicação do método *CARCARÁ Agile Threat Modeling (CATM)* em um contexto real de desenvolvimento ágil baseado no framework Scrum.

A pesquisa possui natureza aplicada e abordagem qualitativa, com foco na análise de um fenômeno contemporâneo em seu contexto real.

3.0.1 Desenho metodológico da pesquisa

A pesquisa foi estruturada da seguinte forma, foi conduzida uma Revisão Rápida da Literatura, com o objetivo de mapear abordagens existentes, identificar lacunas recorrentes e subsidiar a concepção da proposta metodológica.

A partir dos achados da revisão, foi definida a proposta do CATM, orientada à integração da modelagem de ameaças ao fluxo do Scrum. Em seguida, essa proposta será investigada por meio de um estudo de caso qualitativo, planejado para observar sua aplicação em um contexto real de desenvolvimento de software.

Por fim, os dados coletados no estudo de caso serão analisados de forma qualitativa e descritiva, à luz das perguntas de pesquisa, permitindo avaliar como a modelagem de ameaças se integra ao planejamento ágil e quais artefatos e decisões emergem desse processo.

A Figura 4 apresenta, de forma sintética, o desenho metodológico da pesquisa, indicando o encadeamento entre as etapas e os métodos adotados.

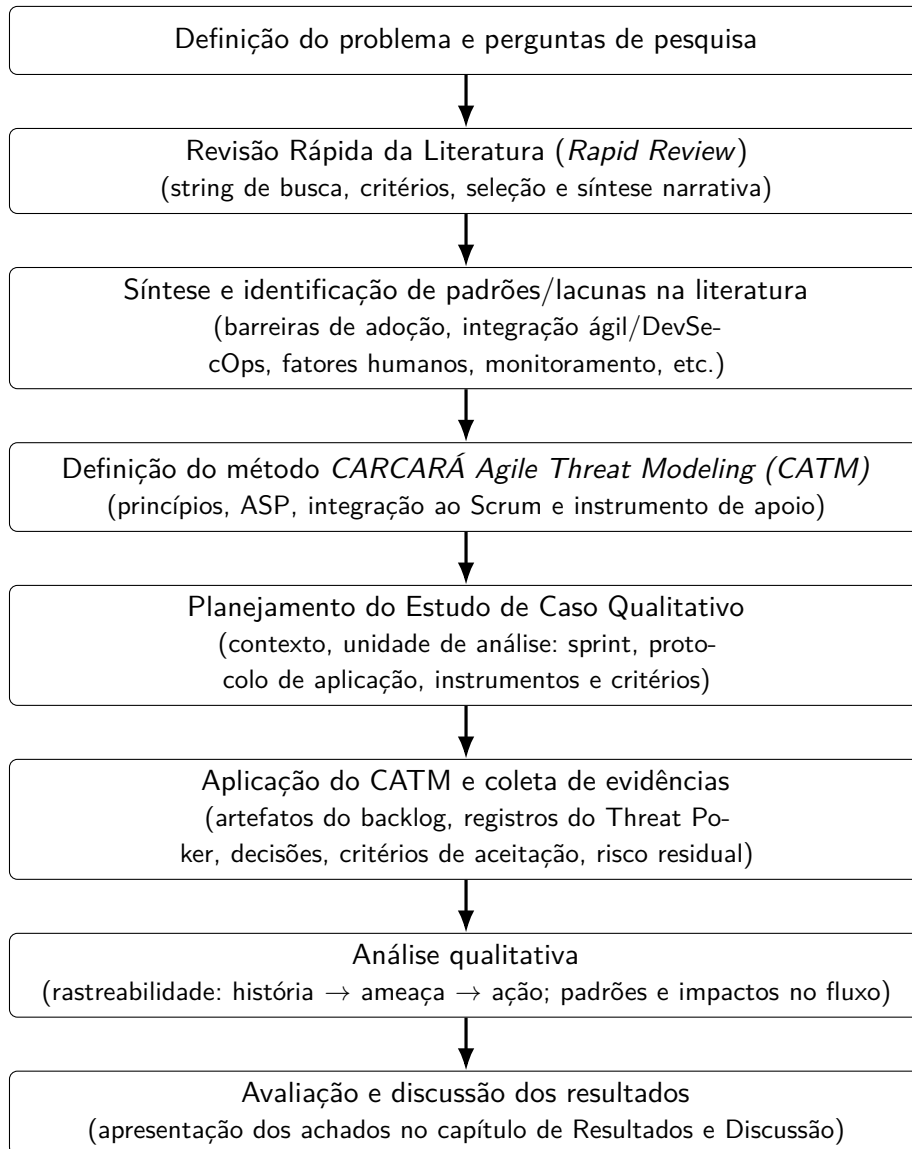


Figura 4 – Desenho metodológico da pesquisa

3.1 RAPID REVIEW

A Revisão Rápida da Literatura (*Rapid Review*) é uma abordagem de síntese secundária caracterizada pela aplicação de atalhos metodológicos em relação às revisões sistemáticas tradicionais, com o objetivo de produzir evidências de forma mais ágil, mantendo níveis aceitáveis de rigor científico. Segundo Grant e Booth (2009), a *Rapid Review* consiste em uma forma estruturada de revisão que simplifica ou omite etapas do processo sistemático completo, sendo adequada quando há restrições de tempo ou quando o objetivo é obter uma visão geral fundamentada de um corpo de conhecimento.

No contexto da Engenharia de Software, revisões rápidas têm sido utilizadas para mapear tendências, identificar lacunas e apoiar decisões de pesquisa aplicada, especialmente em áreas

com evolução acelerada, como DevSecOps e segurança no desenvolvimento de software. Dessa forma, a adoção da *Rapid Review* neste trabalho visa equilibrar abrangência, atualidade e viabilidade metodológica.

3.1.1 Escopo e atalhos metodológicos

Foram adotadas estratégias enxutas, típicas de revisões rápidas, visando garantir aplicabilidade prática dos resultados, sem comprometer o rigor metodológico:

- **Base principal:** IEEE Xplore Digital Library, pela centralidade em Engenharia de Software e Segurança da Informação;
- **Período:** publicações entre 2020 e 2025, contemplando contribuições recentes;
- **Atalhos metodológicos:** não foram consideradas literatura cinzenta, *snowballing* ou meta-análise. A síntese dos resultados foi conduzida de forma narrativa;
- **Processo enxuto:** triagem simplificada dos estudos, com extração de dados estruturada em categorias temáticas.

3.1.2 Estratégia de busca

A estratégia de busca foi elaborada para identificar estudos relacionados à integração de práticas de segurança nas fases iniciais do ciclo de vida do desenvolvimento de software, especialmente em contextos ágeis e DevSecOps. Foram utilizados termos como *DevSecOps*, *Secure Software Development*, *OWASP SAMM*, *shift-left*, *early detection*, *pre-commit*, *security automation* e *industry/organization*.

A string de busca aplicada na base IEEE Xplore foi:

```
((("Abstract": "DevSecOps" OR "Secure Software Development" OR
"Abstract": "OWASP SAMM" OR "security maturity model") OR
("Title": "DevSecOps" OR "Secure Software Development" OR
"Abstract": "OWASP SAMM" OR "security maturity model")) AND
(("Abstract": "shift-left" OR "early detection" OR
"pre-commit" OR "pre-push") OR
("Title": "shift-left" OR "early detection" OR
"pre-commit" OR "pre-push"))) AND
```

```
((("Abstract": "vulnerability detection" OR "security automation") OR  
("Title": "vulnerability detection" OR "security automation")) AND  
((("Abstract": "industry" OR "organization" OR  
"corporate" OR "workplace" OR "firms") OR  
("Title": "industry" OR "organization" OR  
"corporate" OR "workplace" OR "firms"))
```

3.1.3 Critérios de inclusão e exclusão

Foram incluídos estudos que atendessem a pelo menos três dos seguintes critérios:

- foco em *Secure Software Development*, DevSecOps ou metodologias ágeis;
- adoção de práticas de detecção proativa de vulnerabilidades nas fases iniciais do desenvolvimento;
- ênfase no desenvolvedor e na integração ao fluxo DevSecOps;
- alinhamento com frameworks de segurança reconhecidos, como OWASP SAMM, NIST ou ISO/IEC;
- natureza empírica, estudos de caso, mapeamentos ou propostas de solução com aplicabilidade prática.

Foram excluídos estudos com foco exclusivo em segurança operacional ou pós-implantação, domínios excessivamente específicos, trabalhos sem base empírica ou sem aplicabilidade direta ao desenvolvimento seguro de software.

3.1.4 Processo de seleção

O processo de seleção dos estudos seguiu três etapas:

- (i) triagem inicial por título e resumo;
- (ii) aplicação dos critérios de inclusão e exclusão;
- (iii) leitura integral e extração estruturada dos dados dos estudos elegíveis.

No total, foram identificados 217 artigos. Após a triagem por título e resumo, 43 estudos foram selecionados para avaliação mais detalhada. A aplicação dos critérios de inclusão e exclusão resultou em 15 estudos.

A Tabela 1 sintetiza os estudos incluídos na Revisão Rápida da Literatura, os quais abrangem:

- barreiras de adoção de frameworks e metodologias de desenvolvimento seguro;
- integração de práticas de segurança em métodos ágeis e pipelines DevSecOps;
- monitoramento contínuo de segurança e riscos associados à cadeia de suprimentos de software;
- fatores humanos, culturais e mecanismos de conscientização em segurança da informação.

A consolidação desses resultados sustenta a motivação para investigar uma abordagem metodológica integrada ao fluxo do Scrum, orientada à redução de fricção operacional e carga cognitiva, ao mesmo tempo em que produz artefatos de segurança acionáveis no backlog ágil.

Com base na análise dos estudos selecionados, procedeu-se à organização dos trabalhos em categorias temáticas que refletem os principais eixos de investigação da literatura sobre desenvolvimento seguro de software em contextos ágeis. Cada categoria representa um conjunto de preocupações recorrentes e abordagens complementares, conforme descrito a seguir.

A categoria **Segurança em pipelines DevSecOps e automação** reúne estudos que tratam da integração de mecanismos automatizados de segurança ao fluxo de integração e entrega contínua. Esses trabalhos enfatizam o uso de ferramentas, práticas e arquiteturas que permitem a detecção antecipada de vulnerabilidades, a redução de falhas humanas e o aumento da confiabilidade do processo de entrega de software.

A categoria **Modelos preventivos e *shift-left security*** abrange propostas que defendem a incorporação sistemática da segurança desde as fases iniciais do ciclo de vida do desenvolvimento de software. Os estudos desse grupo destacam abordagens preventivas, com foco na redução de custos de correção, na antecipação de riscos e na incorporação de princípios de segurança como parte do processo de engenharia.

A categoria **Modelagem de ameaças e ciclo de vida seguro** contempla trabalhos que propõem modelos estruturados para análise de ameaças e integração da segurança ao longo do ciclo de vida do software. Esses estudos exploram técnicas de raciocínio sobre atacantes e defensores, bem como mecanismos para apoiar a identificação, classificação e mitigação de riscos de forma sistemática.

Quadro 1 – Estudos incluídos na Revisão Rápida da Literatura

Título
“Have Heard of it”: A Study with Practitioners on Adoption of Secure Software Development Frameworks
A Preventive Secure Software Development Model for a Software Factory: A Case Study
A Unified Framework for Automating Software Security Analysis in DevSecOps
Action Research on the DevSecOps Pipeline
Continuous Verification of Open Source Components in a World of Weak Links
Customised Roles in Scrum Teams for the Development of Secure Solution
DASP: A Framework for Driving the Adoption of Software Security Practices
Defender-Attacker Model Based Secure Software Development Lifecycle for Common Web Vulnerabilities
Delegation-Based Agile Secure Software Development Approach for Small and Medium-Sized Businesses
Empirical Investigation of Key Enablers for Secure DevOps Practices
A Design For Comprehensive Information System Management Framework Integrating Secure Software Development, Resource Management, and Real-Time Monitoring
A Secure Software Development Methodology for Enterprise Business Applications
Better Left Shift Security! Framework for Secure Software Development
Building Cyber Resilient Systems from Day 1
Thriving in the era of Hybrid Work: Raising Cybersecurity Awareness using Serious Games in Industry Trainings

A categoria **Papéis, governança e integração organizacional** reúne pesquisas que analisam aspectos organizacionais relacionados à segurança, incluindo a definição de papéis específicos, mecanismos de governança e estratégias de integração entre equipes. Esses trabalhos sugerem desafios associados à adoção de estruturas formais de segurança em ambientes ágeis e os impactos dessas decisões na autonomia e na dinâmica das equipes.

A categoria **Fatores humanos, cultura e conscientização em segurança** agrupa estudos que enfatizam a influência de aspectos comportamentais, culturais e educacionais na adoção de práticas de segurança. Os trabalhos desse grupo destacam a importância da motivação, da conscientização e do engajamento dos desenvolvedores como fatores críticos para o sucesso de iniciativas de segurança no desenvolvimento de software.

Por fim, a categoria **Adoção de frameworks de desenvolvimento seguro** concentra estudos que investigam a utilização prática de frameworks e metodologias de segurança, analisando barreiras, adaptações e limitações enfrentadas pelas organizações. Esses trabalhos

revelam a distância existente entre frameworks de referência e sua aplicação efetiva no cotidiano de equipes ágeis.

Quadro 2 – Artigos selecionados na Rapid Review organizados por categoria temática

Categoria temática	Estudos associados
Segurança em pipelines DevSecOps e automação	▪ A Unified Framework for Automating Software Security Analysis in DevSecOps ▪ Action Research on the DevSecOps Pipeline ▪ Continuous Verification of Open Source Components in a World of Weak Links ▪ Empirical Investigation of Key Enablers for Secure DevOps Practices
Modelos preventivos e <i>shift-left security</i>	▪ A Preventive Secure Software Development Model for a Software Factory: A Case Study ▪ Better Left Shift Security! Framework for Secure Software Development ▪ Building Cyber Resilient Systems from Day 1
Modelagem de ameaças e ciclo de vida seguro	▪ Defender-Attacker Model Based Secure Software Development Lifecycle for Common Web Vulnerabilities ▪ Delegation-Based Agile Secure Software Development Approach for Small and Medium-Sized Businesses
Papéis, governança e integração organizacional	▪ Customised Roles in Scrum Teams for the Development of Secure Solution ▪ A Design for Comprehensive Information System Management Framework Integrating Secure Software Development, Resource Management, and Real-Time Monitoring
Fatores humanos, cultura e conscientização em segurança	▪ DASP: A Framework for Driving the Adoption of Software Security Practices ▪ Thriving in the Era of Hybrid Work: Raising Cybersecurity Awareness using Serious Games in Industry Trainings

Continua na próxima página.

Quadro 2 – continuação

Categoria temática	Estudos associados
Adoção de frameworks de desenvolvimento seguro	▪ “Have Heard of It”: A Study with Practitioners on Adoption of Secure Software Development Frameworks ▪ A Secure Software Development Methodology for Enterprise Business Applications

A organização apresentada na Tabela ?? permite observar tendências recorrentes e lacunas entre os diferentes temas identificados.

A organização dos estudos por categorias temáticas destacam que, embora a literatura apresente propostas consolidadas relacionadas ao desenvolvimento seguro, à automação em pipelines DevSecOps e às estratégias de *shift-left security*, persistem lacunas relevantes no que se refere à operacionalização dessas práticas no nível das histórias de usuário e do planejamento da sprint.

Observa-se, de forma recorrente, a introdução de frameworks e modelos que demandam estruturas adicionais, papéis especializados ou processos paralelos, o que pode aumentar a fricção operacional e a carga cognitiva das equipes de desenvolvimento. Além disso, a literatura revela limitações na tradução de riscos de segurança em unidades de trabalho diretamente acionáveis no backlog ágil.

Esses achados fundamentam a motivação para investigar uma abordagem metodológica integrada ao fluxo do Scrum, orientada à incorporação antecipada da segurança de forma estruturada, pragmática e alinhada às práticas cotidianas das equipes ágeis, preservando a simplicidade do processo e a rastreabilidade das decisões de segurança.

3.1.4.1 Limitações da Revisão Rápida

Embora a Revisão Rápida da Literatura permita a obtenção ágil de evidências relevantes, sua aplicação implica limitações metodológicas. Entre essas limitações, destaca-se a possibilidade de viés na seleção dos estudos, decorrente da redução do escopo de bases consultadas, da simplificação dos critérios de busca e da ausência de etapas mais rigorosas de revisão sistemática, como dupla avaliação independente.

Adicionalmente, a estratégia de busca adotada pode não ter capturado a totalidade dos estudos relevantes sobre o tema, especialmente aqueles publicados fora do período analisado ou

em bases não contempladas. Dessa forma, os resultados desta revisão devem ser interpretados como indicativos, e não exaustivos, sendo utilizados como base para a proposição do método, e não como uma síntese definitiva do estado da arte.

3.2 DERIVAÇÃO DO MÉTODO PROPOSTO: CATM A PARTIR DA LITERATURA

Com base nos resultados da Revisão Rápida da Literatura e nas lacunas identificadas na integração da modelagem de ameaças em ambientes ágeis, foi concebido o método CATM. Esta seção apresenta os princípios e os principais componentes do método proposto, incluindo as ASPs e o instrumento colaborativo CTP.

Os achados da revisão foram utilizados como insumo para a definição dos princípios e elementos constituintes do método CATM. As lacunas identificadas, especialmente relacionadas à fricção operacional, à carga cognitiva e à dificuldade de operacionalização da segurança no nível do backlog, orientaram as decisões de projeto metodológico adotadas neste trabalho (Wee; Kudriavtseva; Gadyatskaya, 2024; Larios-Vargas et al., 2023; Ahmad; Gustavsson; Saeeda, 2023).

Diferentemente das abordagens tradicionais de modelagem de ameaças descritas na literatura, que tendem a se concentrar em fases iniciais de design ou em análises arquiteturais especializadas, o método CATM distingue-se por sua atuação direta no nível do planejamento ágil e das histórias de usuário. Enquanto grande parte dos modelos existentes pressupõe a existência de especialistas em segurança, papéis dedicados ou artefatos técnicos específicos, o CATM foi concebido para operar como uma adaptação leve ao fluxo do Scrum, sem a introdução de novos papéis, cerimônias ou estruturas paralelas de governança.

Outro diferencial central do método reside na transformação explícita de riscos de segurança em unidades acionáveis de trabalho no backlog. A utilização das ASPs permite converter ameaças identificadas durante o planejamento da sprint em ações concretas de mitigação, ajustes em critérios de aceitação ou tarefas técnicas prioritizáveis, preservando a rastreabilidade entre requisitos funcionais, riscos e decisões de segurança. Essa operacionalização busca reduzir a distância frequentemente observada entre a identificação de riscos e sua efetiva incorporação ao processo de desenvolvimento.

Adicionalmente, o CATM incorpora mecanismos de apoio cognitivo baseados em inteligência artificial como subsídio à identificação de ameaças, sem caráter prescritivo ou decisório. Diferentemente de abordagens centradas na automação de controles ou na substituição do

julgamento humano, o uso de IA no CATM tem como objetivo ampliar o repertório de análise da equipe, reduzir carga cognitiva e apoiar discussões colaborativas, especialmente em contextos onde não há especialistas dedicados em segurança.

Neste estudo, o apoio automatizado foi realizado por meio de um modelo de linguagem de grande porte (Large Language Models (LLM)), utilizado exclusivamente como instrumento consultivo para geração de sugestões iniciais de ameaças. Modelos dessa natureza podem produzir respostas imprecisas ou incompletas, fenômeno frequentemente associado às chamadas "alucinações". Por essa razão, as sugestões geradas não são tratadas como decisões automáticas, sendo sempre avaliadas criticamente pela equipe durante a dinâmica colaborativa do CTP.

Os prompts utilizados para interação com o modelo de linguagem, bem como a estrutura de saída adotada para apoiar o registro das ameaças identificadas, encontram-se documentados nos Apêndices ?? e ??, respectivamente. Esses artefatos são apresentados com o objetivo de permitir a reprodutibilidade do instrumento utilizado no apoio à identificação de ameaças durante a aplicação do método.

Por fim, ao integrar a modelagem de ameaças ao *Sprint Planning* e ao utilizar uma dinâmica colaborativa inspirada em práticas ágeis consolidadas, como o *Planning Poker*, o CATM enfatiza o engajamento da equipe e a tomada de decisão consciente sobre riscos. Essa combinação de foco ágil, operacionalização no backlog e apoio cognitivo distingue o método de abordagens existentes e fundamenta sua proposta como uma alternativa pragmática para a incorporação antecipada da segurança em ambientes ágeis.

3.2.1 Atividades de Segurança Proativas (ASP)

A definição das *Atividades de Segurança Proativas* (ASP) emerge da necessidade de tornar decisões de segurança explícitas, acionáveis e compatíveis com o fluxo de trabalho ágil. No contexto deste trabalho, o termo ASP é empregado em dois níveis conceituais complementares: (i) como unidade mínima de ação de segurança integrada ao backlog ágil e (ii) como mecanismo de apoio à priorização dessas ações, baseado na combinação entre risco e esforço de mitigação.

A métrica ASP foi concebida como um mecanismo simples de apoio à priorização de ações de segurança no contexto do planejamento ágil. Sua formulação foi definida como uma decisão de design metodológico orientada à simplicidade operacional e à transparência na tomada de decisão durante o *Sprint Planning*. A combinação entre risco (R) e esforço de mitigação (EM) busca refletir a relação entre impacto potencial da ameaça e viabilidade de implementação

da mitigação, permitindo à equipe identificar ações de segurança com maior retorno relativo dentro das restrições da sprint.

A literatura sobre desenvolvimento seguro e DevSecOps reconhece que, embora práticas preventivas sejam amplamente recomendadas, sua operacionalização no nível do backlog ágil permanece um desafio recorrente (Núñez; Lindo; Rodríguez, 2020; Akbar; AlSanad, 2025). Frameworks como o NIST SSDF e o OWASP SAMM enfatizam a importância de antecipar decisões de segurança ao longo do ciclo de vida do software. Entretanto, tais modelos atuam predominantemente em níveis abstratos de práticas, domínios ou atividades amplas, oferecendo orientação limitada sobre como traduzir riscos identificados em unidades de trabalho diretamente integráveis ao planejamento ágil.

Nesse cenário, decisões de segurança tendem a permanecer implícitas, dispersas em discussões técnicas ou tratadas como responsabilidades informais dos desenvolvedores. As ASPs são concebidas para reduzir essa lacuna ao representar ações mínimas, explícitas e rastreáveis de segurança, derivadas diretamente da identificação de ameaças associadas às histórias de usuário analisadas durante o planejamento da sprint. Cada ASP corresponde a uma ação concreta de mitigação, prevenção ou redução de risco, formulada de modo a ser compreensível, priorizável e executável no contexto do Scrum.

Essa concepção se alinha ao princípio de *shift-left security*, ao transformar riscos identificados no início do ciclo de desenvolvimento em ações executáveis antes da implementação. Além disso, a definição das ASPs é fundamentada por evidências relacionadas a fatores humanos e carga cognitiva. Estudos como o framework DASP indicam que decisões abstratas de segurança impõem elevado esforço cognitivo aos desenvolvedores, especialmente em equipes que não dispõem de especialistas dedicados (Larios-Vargas et al., 2023). Ao estruturar decisões de segurança como atividades pequenas, contextualizadas e integradas ao backlog, as ASPs buscam reduzir fricção operacional e favorecer a tomada de decisão no fluxo ágil.

Além de representar uma unidade mínima de ação, cada ASP é associada a um valor de priorização, calculado a partir da combinação entre o impacto do risco identificado e o esforço necessário para sua mitigação. Esse valor tem como objetivo apoiar a tomada de decisão durante o *Sprint Planning*, tornando explícita a relação entre severidade do risco e custo relativo de correção.

O valor de priorização da ASP é obtido conforme a Equação 3.1:

$$ASP = R \times EM \quad (3.1)$$

onde **R** representa o fator de *Risco*, associado ao impacto potencial da ameaça sobre o negócio, e **EM** representa o *Esforço de Mitigação*, correspondente ao custo relativo para implementar a ação corretiva, considerando complexidade técnica, tempo e recursos envolvidos.

A escolha da operação multiplicativa busca reforçar a priorização de ameaças que combinam alto impacto com elevada viabilidade de mitigação. Ao utilizar a multiplicação entre os fatores R e EM, o modelo produz um efeito de amplificação quando ambos assumem valores elevados, distinguindo de forma mais clara as mitigações consideradas vantajosas. Diferentemente de uma soma simples, que poderia suavizar diferenças entre combinações distintas de risco e esforço, a multiplicação preserva a proporcionalidade entre os fatores e reduz o escore quando um dos componentes apresenta valor baixo. Dessa forma, ameaças de baixo impacto, ainda que de fácil correção, ou ameaças de alto impacto com elevado custo de mitigação tendem a gerar valores intermediários, favorecendo a priorização de ações com melhor relação entre benefício e viabilidade.

Alternativas como combinações ponderadas ou estruturas baseadas em divisão, similares ao modelo Weighted Shortest Job First (WSJF), poderiam ser consideradas. Contudo, optou-se por uma formulação multiplicativa por sua simplicidade operacional, facilidade de compreensão pela equipe e adequação ao contexto ágil, no qual decisões precisam ser tomadas de forma rápida e transparente. Essa escolha privilegia pragmatismo e clareza, mantendo alinhamento com o objetivo de leveza metodológica do CATM.

As escalas adotadas para os fatores de risco e esforço de mitigação são discretas e ordinalizadas, conforme apresentado nas Tabelas 1 e 2. A atribuição dos valores foi definida de forma que valores mais elevados representem mitigações mais vantajosas quando combinadas, priorizando ameaças de alto impacto associadas a baixo esforço de correção.

Tabela 1 – Escala de avaliação do fator Risco (R)

Risco	Valor
Crítico	10
Alto	8
Médio	3
Baixo	1

Tabela 2 – Escala de avaliação do fator Esforço de Mitigação (EM)

Esforço de Mitigação	Valor
Muito alto	3
Alto	5
Médio	8
Baixo	10

A interpretação do valor resultante do ASP permite apoiar a priorização das ações de segurança no backlog da sprint. Valores elevados indicam mitigações com alto retorno relativo, por combinarem riscos relevantes e baixo esforço de implementação, enquanto valores reduzidos sugerem menor atratividade, seja por baixo impacto, seja por elevado custo de correção.

3.2.1.1 Exemplo de aplicação dos critérios de risco e esforço

Para ilustrar a aplicação prática dos critérios de risco e esforço de mitigação, considere a seguinte história de usuário:

"Como usuário autenticado, desejo atualizar meus dados cadastrais para manter minhas informações atualizadas."

Durante a análise da história, foi identificada a ameaça de *alteração indevida de dados (tampering)*, associada à ausência de validação adequada no backend.

A avaliação dos critérios foi realizada da seguinte forma:

- **Risco (R)**: classificado como *Alto* (valor 8), considerando o impacto potencial sobre a integridade dos dados e a possibilidade de exploração por usuários maliciosos.
- **Esforço de Mitigação (EM)**: classificado como *Médio* (valor 8), uma vez que a implementação requer validação adicional no backend e ajustes nas regras de autorização.

Com base nesses valores, o cálculo do ASP resulta em:

$$ASP = 8 \times 8 = 64 \quad (3.2)$$

O valor obtido indica uma ação de segurança com prioridade elevada, combinando impacto relevante e esforço viável de implementação. A partir dessa avaliação, é possível derivar uma ASP concreta, incorporada ao backlog da sprint, incluindo critérios de aceitação relacionados à validação de entrada e ao controle de autorização.

Esse exemplo evidencia como os critérios definidos permitem transformar ameaças identificadas em ações práticas, prioritizáveis e integradas ao fluxo ágil de desenvolvimento.

Embora o ASP não seja equivalente a modelos formais de priorização ágil, sua formulação dialoga com abordagens consolidadas tanto no contexto de engenharia de software quanto de segurança.

No âmbito ágil, uma referência relevante é o modelo *Weighted Shortest Job First* (WSJF), amplamente utilizado no framework Scaled Agile Framework (SAFe) (Scaled Agile, Inc., 2023). O WSJF prioriza itens com base na relação entre custo do atraso e tamanho do trabalho, buscando maximizar valor econômico. De forma análoga, o ASP estabelece uma relação entre impacto (risco) e esforço de implementação, orientando a priorização de ações de segurança no backlog. A principal diferença reside no fato de que o ASP é especializado para o domínio de segurança, enquanto o WSJF possui uma abordagem generalista orientada a valor de negócio.

No contexto de segurança da informação, sistemas como o CVSS são amplamente utilizados para classificar a severidade de vulnerabilidades com base em fatores como impacto, explorabilidade e complexidade de ataque. Diferentemente do CVSS, que possui foco na avaliação técnica de vulnerabilidades já identificadas, o ASP é orientado à tomada de decisão durante o planejamento ágil, incorporando explicitamente o esforço de mitigação como variável de priorização. Essa característica permite que decisões de segurança sejam contextualizadas no fluxo de desenvolvimento, e não tratadas de forma isolada.

Nesse contexto, a métrica proposta não foi validada por meio de estudos quantitativos comparativos com essas abordagens. Ainda assim, sua aplicação no estudo de caso demonstrou utilidade prática na priorização de ações de segurança, contribuindo para a explicitação e rastreabilidade de decisões no backlog. Investigações futuras podem explorar a validação empírica da métrica em diferentes contextos e sua comparação sistemática com modelos estabelecidos.

3.2.2 Mecânica do Carcará Threat Poker

O CTP é o mecanismo central do método CATM para apoiar a identificação, discussão e priorização colaborativa de ameaças de segurança no contexto do planejamento ágil. Inspirado em práticas consolidadas de estimativa colaborativa, como o *Planning Poker*, o instrumento foi concebido para estruturar o raciocínio sobre riscos de segurança de forma leve, iterativa e integrada ao fluxo do Scrum, sem a introdução de novos papéis ou cerimônias.

A mecânica do CTP é aplicada principalmente durante o *Sprint Planning*, tomando como ponto de partida as histórias de usuário priorizadas para a sprint. Diferentemente de abordagens tradicionais de modelagem de ameaças centradas na arquitetura ou em artefatos técnicos complexos, o foco do instrumento está na análise dos riscos associados às funcionalidades a serem desenvolvidas, conforme descritas nas histórias de usuário.

O processo inicia-se com a leitura e contextualização da história de usuário, incluindo seu objetivo funcional, atores envolvidos e principais fluxos esperados. A partir dessa descrição textual, a equipe é estimulada a refletir sobre possíveis cenários de abuso, falhas de segurança ou exposições de risco associadas à funcionalidade proposta. Esse raciocínio pode ser apoiado por taxonomias de referência amplamente utilizadas na literatura e na prática, como OWASP Top 10, CWE e *Cheat Sheets*, bem como por modelos de classificação de severidade, como o CVSS.

Como apoio consultivo ao processo, o método admite o uso de instrumentos automatizados ou baseados em inteligência artificial para sugerir ameaças potenciais a partir da descrição da história de usuário. Essas sugestões não possuem caráter prescritivo ou decisório, atuando apenas como subsídio técnico para ampliar o repertório de análise da equipe e reduzir a carga cognitiva associada à identificação manual de riscos, especialmente em contextos sem especialistas dedicados em segurança.

Após a identificação das ameaças relevantes, cada ameaça é discutida coletivamente pela equipe, considerando seu impacto potencial no negócio e a viabilidade de mitigação no contexto da sprint. Essa discussão culmina na atribuição de valores qualitativos ou quantitativos para os fatores de *Risco* e *Esforço de Mitigação*, conforme definido no modelo de ASP. O objetivo dessa etapa não é obter precisão absoluta, mas promover alinhamento, transparência e tomada de decisão consciente sobre quais riscos devem ser tratados de forma antecipada.

Com base na combinação desses fatores, as ameaças consideradas prioritárias são convertidas em ASP, formuladas como ações concretas de mitigação, ajustes em critérios de aceitação ou tarefas específicas a serem incorporadas ao backlog da sprint. Dessa forma, os resultados do CTP deixam de ser apenas discussões abstratas e passam a se materializar em unidades de trabalho rastreáveis, alinhadas ao planejamento ágil.

A mecânica do CTP preserva os princípios fundamentais do Scrum ao evitar a criação de fluxos paralelos de controle ou artefatos externos. Ao integrar a discussão de ameaças diretamente ao momento de planejamento e priorização, o instrumento busca operacionalizar a lógica do *shift-left security*, promovendo a antecipação de decisões de segurança e sua

incorporação explícita no ciclo incremental de desenvolvimento.

3.2.3 Exemplo ilustrativo de aplicação do CTP e ASP

Esta subseção apresenta um exemplo ilustrativo e simulado de aplicação do CTP, com o objetivo de explicitar a dinâmica do método CATM no planejamento ágil. O exemplo não corresponde aos dados empíricos do estudo de caso, sendo utilizado exclusivamente para fins explicativos e metodológicos.

3.2.3.0.1 *História de usuário*

Considere a seguinte história de usuário priorizada para uma sprint:

“Como usuário autenticado, desejo recuperar minha senha por e-mail para poder acessar novamente o sistema caso eu a esqueça.”

Durante o *Sprint Planning*, após a análise funcional da história, a equipe inicia a aplicação do CTP. Diferentemente de abordagens que assumem conhecimento prévio em segurança, parte-se do pressuposto de que, de forma espontânea, os desenvolvedores tendem a não levantar ameaças de segurança de maneira sistemática, especialmente em equipes sem especialistas dedicados.

3.2.3.0.2 *Apoio inicial da IA na identificação de ameaças*

Diante dessa limitação, a equipe utiliza um instrumento automatizado baseado em inteligência artificial como apoio inicial à análise. A IA recebe como entrada a descrição textual da história de usuário e sugere um conjunto de possíveis ameaças associadas à funcionalidade proposta, acompanhadas de descrições técnicas e exemplos de exploração.

Entre as ameaças sugeridas pelo instrumento, destacam-se, por exemplo:

- enumeração de contas por meio de respostas distintas na recuperação de senha;
- ausência de limitação de tentativas de solicitação de recuperação;
- reutilização ou expiração inadequada de tokens de redefinição;
- exposição de informações sensíveis em mensagens de erro.

As sugestões fornecidas pela IA não possuem caráter prescritivo ou decisório. Elas atuam como ponto de partida para a discussão, ampliando o repertório de análise da equipe e reduzindo a carga cognitiva associada à identificação manual de riscos.

3.2.3.0.3 *Discussão colaborativa orientada pelas sugestões*

A partir das ameaças sugeridas, a equipe discute coletivamente quais cenários são realistas e relevantes no contexto específico do sistema em desenvolvimento. Nessa etapa, as descrições detalhadas fornecidas pela IA são utilizadas como apoio técnico para compreender o funcionamento das ameaças, seus impactos potenciais e formas comuns de mitigação.

Por exemplo, ao analisar a ameaça de enumeração de contas, a equipe avalia que a funcionalidade de recuperação de senha pode revelar indiretamente a existência de usuários válidos, o que representa um risco relevante do ponto de vista de segurança e privacidade.

3.2.3.0.4 *Atribuição de valores e cálculo do ASP*

Após selecionar as ameaças consideradas pertinentes, cada membro da equipe atribui individualmente valores aos fatores de *Risco* (R) e *Esforço de Mitigação* (EM), utilizando cartões ou registro digital, de forma semelhante à dinâmica do *Planning Poker*.

Os valores são então revelados simultaneamente e discutidos em caso de divergência, até que se alcance um consenso razoável sobre a classificação.

A classificação dos fatores de risco e esforço é orientada por referências consolidadas de segurança e pela experiência coletiva da equipe. O fator de *Risco* considera principalmente o impacto potencial da ameaça e sua probabilidade de exploração, podendo ser apoiado por referências como OWASP Top 10, CWE e modelos de severidade como o CVSS. Já o fator de *Esforço de Mitigação* reflete a complexidade técnica necessária para implementar a proteção, considerando aspectos como alterações arquiteturais, dependências externas e impacto no escopo da sprint.

O cálculo do ASP é realizado de forma transparente durante a sessão, permitindo que a equipe visualize o impacto da combinação entre risco e esforço na decisão de priorização.

No caso da ameaça de enumeração de contas, são atribuídos:

- **Risco (R):** Alto (8), devido ao impacto potencial sobre a confidencialidade e à possibilidade de exploração automatizada;

- **Esforço de Mitigação (EM):** Baixo (10), considerando a adoção de respostas genéricas e mecanismos simples de controle.

Com base nesses valores, o ASP associado à ameaça é calculado como:

$$ASP = 8 \times 10 = 80$$

3.2.3.0.5 Conversão em Atividade de Segurança Proativa

Diante do valor elevado de ASP, a equipe decide tratar a ameaça de forma antecipada, convertendo-a em uma ASP a ser incorporada ao backlog da sprint.

Dessa forma, estabelece-se rastreabilidade explícita entre história de usuário, ameaça identificada, decisão de priorização e ação de mitigação planejada.

No exemplo, a atividade é formulada como:

“Implementar resposta uniforme para solicitações de recuperação de senha, independente da existência do usuário, com limitação de tentativas por endereço IP.”

Alternativamente, parte da mitigação pode ser incorporada diretamente aos critérios de aceitação da história de usuário, tornando explícitas as preocupações de segurança desde o planejamento.

3.2.3.0.6 Resultado do processo ilustrativo

Ao final do processo ilustrativo, observa-se que o CTP:

- viabiliza a identificação de ameaças mesmo quando a equipe não as levanta espontaneamente;
- utiliza a IA como apoio técnico e cognitivo, e não como agente decisório;
- estrutura a discussão de riscos a partir de sugestões contextualizadas;
- converte decisões de segurança em ações rastreáveis no backlog da sprint;
- integra a segurança ao planejamento ágil sem introduzir novos papéis ou cerimônias.

Esse exemplo evidencia como o CTP operacionaliza a lógica do *shift-left security*, promovendo a antecipação de decisões de segurança no planejamento ágil e reduzindo a dependência de conhecimento especializado prévio, mantendo aderência aos princípios do Scrum.

3.2.4 Posicionamento do CATM em relação a abordagens tradicionais

A modelagem de ameaças tradicionalmente é conduzida a partir de análises arquiteturais estruturadas, como no caso do modelo STRIDE, sendo frequentemente aplicada em fases formais de design ou conduzida por especialistas em segurança. Embora essas abordagens sejam amplamente reconhecidas, sua integração ao fluxo ágil cotidiano apresenta desafios relacionados à fricção operacional e à necessidade de conhecimento especializado.

O método CARCARÁ Agile Threat Modeling (CATM) não propõe substituir taxonomias consolidadas, mas operacionalizá-las de forma leve e integrada ao planejamento ágil.

Embora o CATM concentre sua análise no nível das histórias de usuário, reconhece-se que certos riscos de segurança podem emergir da interação entre diferentes funcionalidades ou componentes do sistema. Nesses casos, ameaças relacionadas à integração podem não ser plenamente capturadas quando as histórias são analisadas de forma isolada. Para mitigar essa limitação, o método incentiva que riscos identificados durante o planejamento sejam revisitados em cerimônias subsequentes do Scrum, como a *Sprint Review* e a *Retrospective*, permitindo a identificação de ameaças emergentes decorrentes da integração entre funcionalidades implementadas ao longo das sprints.

A tabela 2 sintetiza as principais diferenças estruturais entre abordagens tradicionais e o CATM.

Quadro 2 – Comparação entre abordagens tradicionais de modelagem de ameaças e o método CARCARÁ

Dimensão	Modelagem tradicional	CARCARÁ (CATM)
Momento de aplicação	Geralmente durante design arquitetural ou fases iniciais formais do SDLC	Integrado ao <i>Sprint Planning</i> , no fluxo ágil recorrente
Unidade de análise	Componentes arquiteturais, fluxos de dados ou diagramas técnicos	Histórias de usuário priorizadas para a sprint
Integração com métodos ágeis	Frequentemente executada como atividade paralela ou especializada	Incorporada às cerimônias existentes, sem novos papéis
Necessidade de especialista	Alta dependência de conhecimento prévio em segurança	Projetado para equipes sem especialista dedicado
Suporte automatizado	Normalmente manual ou baseado em checklists	Admite suporte de IA como apoio consultivo
Priorização explícita	Nem sempre integrada ao backlog	Formalizada por meio do cálculo $R \times EM$ (ASP)
Artefato resultante	Relatórios técnicos ou listas de ameaças	Atividades de Segurança Proativas rastreáveis no backlog
Foco cultural	Análise técnica estruturada	Integração leve com foco comportamental e redução de fricção

3.3 ESTUDO DE CASO QUALITATIVO

Esta pesquisa adota como segunda vertente metodológica um estudo de caso qualitativo. De acordo com Yin (2014), o estudo de caso é uma estratégia de pesquisa adequada para investigar fenômenos contemporâneos em profundidade, especialmente quando os limites entre o fenômeno e o contexto não estão claramente definidos e quando o pesquisador possui pouco controle sobre os eventos observados.

O uso do estudo de caso justifica-se pelo objetivo de compreender como práticas de modelagem de ameaças podem ser integradas ao processo de desenvolvimento ágil em um contexto real, preservando o fluxo natural do Scrum. Essa abordagem permite analisar decisões, artefatos e interações no ambiente onde o fenômeno ocorre, alinhando-se à natureza aplicada e exploratória desta pesquisa. (Yin, 2014)

O objetivo do estudo de caso é analisar como a modelagem de ameaças pode ser integrada ao processo de desenvolvimento ágil por meio da aplicação do método CATM em um contexto de uso do Scrum. A unidade de análise corresponde ao processo de planejamento e execução

de uma sprint, considerando suas principais cerimônias, artefatos e decisões associadas.

3.3.1 Delineamento do Estudo de Caso

O estudo de caso adotado nesta pesquisa caracteriza-se como um **estudo de caso único, de natureza exploratória e instrumental**, conforme classificação proposta por Yin (2014). Trata-se de um caso único por concentrar-se em um único projeto de desenvolvimento de software, inserido em um contexto organizacional específico. Possui caráter exploratório por investigar a aplicação de um método proposto (CATM) em ambiente real, buscando compreender sua integração ao fluxo ágil. É instrumental na medida em que o caso é utilizado como meio para avaliar e compreender o funcionamento do artefato metodológico desenvolvido.

Unidade de análise. A unidade de análise adotada corresponde ao processo de planejamento e execução de uma sprint no contexto do Scrum. De forma mais específica, são analisadas as histórias de usuário selecionadas para a sprint e as decisões de segurança associadas a elas, incluindo identificação de ameaças, definição de Atividades de Segurança Proativas (ASP) e registro de risco residual quando aplicável.

Contexto do estudo. O estudo foi conduzido em um projeto de desenvolvimento de software que adota o framework Scrum como método de gestão ágil. A equipe é composta por desenvolvedores e demais papéis previstos no Scrum, não contando com especialista dedicado exclusivamente à segurança da informação, característica coerente com o objetivo da pesquisa de avaliar a aplicabilidade do método em equipes ágeis típicas.

Período de observação. A aplicação do método foi realizada ao longo de uma única sprint, com duração aproximada de 2 semanas. Durante esse período, o método foi aplicado principalmente nas cerimônias de *Sprint Planning*, sendo acompanhada também sua repercussão nas demais cerimônias, como *Review* e *Retrospective*.

3.3.2 Aplicação do CATM no estudo de caso

No contexto do estudo de caso, o método CATM será aplicado como uma adaptação leve ao fluxo do Scrum, sem a introdução de novos papéis, artefatos ou cerimônias formais. A modelagem de ameaças será incorporada principalmente ao *Sprint Planning*, momento em que as histórias de usuário priorizadas serão analisadas sob a perspectiva de riscos de segurança.

A análise ocorrerá a partir da descrição textual das histórias de usuário, permitindo a identificação antecipada de ameaças potenciais antes do início da implementação. A partir

dessa identificação, poderão ser definidas ações de mitigação, ajustes em critérios de aceitação ou a criação de atividades de segurança integradas ao backlog da sprint.

O CATM será aplicado às histórias de usuário priorizadas para a sprint analisada, permitindo observar como a identificação de ameaças poderá ser integrada ao planejamento ágil. Entretanto, o método não pressupõe necessariamente sua aplicação a todas as histórias em ambientes de produção. Em cenários com grande volume de backlog, sua utilização poderá ser orientada por critérios discricionários da equipe, como criticidade da funcionalidade, exposição a dados sensíveis ou complexidade das interações entre componentes do sistema.

Adicionalmente, o método foi concebido para equipes que não possuem especialistas dedicados em segurança. Nesse contexto, o apoio consultivo de inteligência artificial e o uso de taxonomias reconhecidas, como OWASP Top 10 e CWE, funcionarão como instrumentos de suporte cognitivo para ampliar o repertório de análise da equipe durante a identificação de ameaças.

3.3.3 Procedimento de instrução inicial do método

Antes do início da observação das sprints incluídas no estudo de caso, será realizada uma instrução inicial com os membros da equipe sobre a aplicação do método CATM, com ênfase na mecânica do CTP durante o *Sprint Planning*. Essa instrução terá caráter introdutório e duração reduzida, sendo conduzida imediatamente antes do planejamento da sprint.

O procedimento contemplará: (i) a explicação do objetivo do CATM como abordagem leve para antecipar a identificação de ameaças no planejamento ágil; (ii) a demonstração do fluxo de aplicação do CTP a partir de uma história de usuário; e (iii) o esclarecimento de que as sugestões eventualmente geradas por apoio automatizado (incluindo recursos baseados em inteligência artificial) possuem caráter consultivo, servindo como subsídio técnico para discussão em equipe, sem substituir o julgamento e a decisão coletiva dos participantes.

A instrução também apresentará a lógica de conversão de ameaças em ASPs e o registro dos resultados no backlog da sprint, reforçando que a priorização e a aceitação de risco permanecem sob responsabilidade da equipe do projeto, conforme o fluxo regular do Scrum.

3.3.4 Coleta de dados

A coleta de dados será realizada por meio de observação participante das cerimônias do processo de desenvolvimento ágil e pela análise documental dos artefatos produzidos ao longo

das sprints observadas. O foco da coleta estará nas evidências geradas durante as cerimônias do Scrum, Sprint Planning, Daily Scrum, Review e Retrospective, nas quais a modelagem de ameaças será aplicada por meio do método CATM, operacionalizado pela mecânica do CTP.

Os dados coletados terão natureza documental e processual, não envolvendo entrevistas, questionários ou depoimentos individuais. As evidências empíricas serão compostas pelos registros gerados durante a aplicação do método, pelos artefatos do backlog da sprint (histórias de usuário, ASPs, critérios de aceitação e registros de risco) e pelas anotações estruturadas realizadas pelo pesquisador.

As observações serão registradas por meio de anotações textuais estruturadas, organizadas por sprint e por história de usuário, conforme instrumento apresentado no Apêndice C. Esse instrumento orientará o registro sistemático das histórias analisadas, das ameaças identificadas, das decisões de segurança tomadas e das mudanças observadas no fluxo de desenvolvimento.

3.3.5 Papel do pesquisador

O pesquisador atuará como observador participante com intervenção mínima ao longo do estudo de caso. Sua atuação será restrita à apresentação inicial do instrumento de apoio e ao esclarecimento pontual de seu funcionamento técnico durante as cerimônias observadas.

O pesquisador não participará das decisões de priorização, definição de requisitos, implementação de funcionalidades ou aceitação de riscos, as quais permanecerão sob responsabilidade exclusiva da equipe do projeto.

3.3.6 Avaliação do método CATM

A avaliação do método CATM tem como objetivo verificar sua aplicabilidade prática e sua clareza operacional no contexto de um processo ágil baseado em Scrum, considerando sua proposta de integração à rotina de planejamento e execução de uma sprint sem a introdução de novos papéis ou cerimônias formais. A avaliação possui caráter qualitativo, baseada em evidências processuais e documentais geradas durante a aplicação do método no estudo de caso, em consonância com a natureza exploratória desta pesquisa e com a lógica de investigação de fenômenos contemporâneos em contexto real (Yin, 2014).

3.3.6.1 Critérios de avaliação

Com base nas lacunas e barreiras apontadas pela literatura (por exemplo, fricção operacional, complexidade, carga cognitiva e desconexão com o fluxo ágil), a avaliação será orientada pelos seguintes critérios:

- **Aplicabilidade no fluxo Scrum:** grau em que o CATM pode ser executado no *Sprint Planning* e conectado ao backlog sem demandar cerimônias paralelas;
- **Clareza operacional:** nível de compreensão e uso consistente dos elementos do método (por exemplo, registro de ameaças, ações/ASPs e ajustes em critérios de aceitação) a partir das histórias de usuário;
- **Viabilidade operacional:** evidências de adoção com esforço compatível com o ritmo da sprint, sem depender de papéis especializados, ferramentas adicionais ou mudanças estruturais no processo;
- **Utilidade percebida no processo:** evidências indiretas de utilidade observadas no processo decisório (por exemplo, ameaças convertidas em ações, mudanças em critérios de aceitação, priorização explícita e registro de risco residual).

3.3.6.2 Como os critérios serão aplicados

Os critérios serão aplicados por meio da análise das evidências produzidas durante as sprints observadas, considerando:

- **Rastreabilidade** entre elementos do processo: história de usuário → ameaça(s) → ação(ões) no backlog (ASPs) e/ou ajuste(s) em critério(s) de aceitação → registro de risco residual quando aplicável;
- **Consistência de registro:** presença de registros completos e padronizados no instrumento de coleta (Apêndice C), permitindo comparar histórias e sprints;
- **Evidências de integração ao fluxo:** ocorrências observáveis nas cerimônias (especialmente *Sprint Planning* e *Retrospective*) em que decisões de segurança são discutidas e traduzidas em artefatos do Scrum, sem interrupção significativa do fluxo.

Dessa forma, os critérios não serão avaliados por entrevistas ou questionários, mas por evidências processuais e documentais geradas no uso real do método, mantendo aderência ao desenho de coleta definido nesta pesquisa.

3.3.6.3 Indicadores objetivos de avaliação

Além dos critérios qualitativos previamente descritos, a avaliação do método CATM considerará indicadores objetivos derivados dos artefatos produzidos durante a aplicação na sprint observada. Esses indicadores têm caráter descritivo e visam oferecer evidências empíricas mensuráveis sobre a integração da modelagem de ameaças ao fluxo ágil.

Os principais indicadores considerados são apresentados na Tabela 3.

Tabela 3 – Indicadores objetivos utilizados na avaliação do CATM

Indicador	Descrição
Número de histórias analisadas	Quantidade de histórias de usuário submetidas à modelagem de ameaças na sprint
Número de ameaças identificadas	Total de ameaças registradas durante a aplicação do CTP
Número de ASPs criadas	Total de Atividades de Segurança Proativas derivadas das ameaças identificadas
Percentual de histórias com ASP	Relação entre histórias modeladas e histórias que resultaram na criação de ASPs
Número de critérios de aceitação modificados	Quantidade de histórias cujo critério de aceitação foi ajustado após a modelagem
Registro de risco residual	Verificação da existência de ameaças discutidas que não foram priorizadas na sprint

3.3.6.4 Tratamento e análise dos dados

Do ponto de vista analítico, será empregada uma estratégia de análise qualitativa de padrões, inspirada na lógica de *pattern matching* proposta por Yin (2014). As evidências coletadas serão organizadas por sprint e por história de usuário e examinadas à luz das Questões de Pesquisa (QP1, QP2 e QP3), com o objetivo de identificar recorrências, convergências e variações no processo de integração da modelagem de ameaças ao fluxo ágil.

Será utilizada análise temática de caráter descritivo para categorizar os tipos de ameaças identificadas, as decisões de segurança produzidas e os impactos observados nas cerimônias do Scrum. Para os dados de natureza quantitativa, como número de histórias analisadas,

quantidade de ameaças identificadas e número de ASPs priorizadas, será aplicada análise descritiva simples, sem realização de inferência estatística.

O tratamento dos dados ocorrerá de forma qualitativa e descritiva. As evidências coletadas, incluindo anotações estruturadas por sprint e por história de usuário, artefatos do backlog e registros gerados durante as sessões do CTP, serão organizadas em registros por sprint e posteriormente categorizadas conforme os critérios de avaliação definidos nesta subseção.

A análise buscará identificar padrões recorrentes, variações e relações entre histórias e decisões de segurança, tais como tipos de ameaças mais frequentes, formas de mitigação recorrentes, padrões de conversão de ameaças em ações no backlog e situações em que a discussão não resultou em artefatos acionáveis. Quando pertinente, os achados serão consolidados em quadros descritivos que evidenciem a rastreabilidade e os resultados gerados pelo método.

Por fim, será empregada triangulação entre fontes, considerando a observação das cerimônias, os registros estruturados e os artefatos do backlog, com o objetivo de aumentar a consistência interpretativa e reduzir vieses associados a uma única fonte de evidência, conforme orientações de Yin (2014). Os resultados dessa análise serão apresentados e discutidos no capítulo de Resultados e Discussão.

3.4 LIMITAÇÕES DA PESQUISA

As limitações desta pesquisa decorrem tanto das escolhas realizadas na condução da Revisão Rápida da Literatura quanto do delineamento do estudo de caso qualitativo. Essas limitações são inerentes ao desenho metodológico adotado e devem ser explicitadas para delimitar o alcance e a interpretação dos resultados que serão apresentados no capítulo de Resultados.

No que se refere à Revisão Rápida da Literatura, as principais limitações estão associadas à utilização de uma única base de dados, à exclusão de literatura cinzenta e à ausência de meta-análise quantitativa. Essas decisões metodológicas, características de revisões rápidas, priorizam agilidade e aplicabilidade prática, mas podem restringir a abrangência do mapeamento realizado. Tais limitações são mitigadas por meio da definição criteriosa da estratégia de busca e da categorização temática dos estudos incluídos, permitindo a identificação de padrões e lacunas relevantes para a pesquisa.

Em relação ao estudo de caso qualitativo, a primeira limitação diz respeito à **abrangência do contexto analisado**. O estudo será conduzido em um único projeto de desenvolvimento de software, inserido em uma organização específica. Essa delimitação implica que os resultados

não terão como objetivo a generalização estatística, mas sim a generalização analítica, conforme defendido por Yin (2014). O propósito é contribuir para a compreensão do fenômeno investigado e para a reflexão teórica sobre a integração da modelagem de ameaças em contextos ágeis.

Outra limitação refere-se à **caracterização da equipe participante**. O método proposto será aplicado em uma equipe que utiliza Scrum e que não dispõe, necessariamente, de especialistas dedicados em segurança da informação. Essa característica pode influenciar o nível de profundidade técnica das análises de risco realizadas durante a aplicação do método, uma vez que o repertório prévio da equipe pode impactar a identificação e a priorização de ameaças.

Destaca-se também a **ausência de grupo de controle ou comparação empírica com outras abordagens de modelagem de ameaças**. O método CATM será aplicado em uma sprint específica, sem comparação formal com ciclos conduzidos sem sua aplicação ou com modelos tradicionais de modelagem de ameaças, como aplicações formais de STRIDE. Dessa forma, não será possível estabelecer relações causais entre os resultados e a adoção do método, sendo a análise limitada à descrição e interpretação das evidências coletadas.

O estudo de caso apresenta ainda uma limitação relacionada ao **recorte temporal**. A aplicação e avaliação do método estarão concentradas em um período correspondente a uma sprint, o que pode restringir a observação de efeitos de médio e longo prazo, como a consolidação das práticas de segurança, a evolução da maturidade da equipe ou impactos cumulativos no produto de software.

Outra limitação diz respeito à **dependência do instrumento baseado em inteligência artificial utilizado como apoio à identificação de ameaças**. Embora o método CATM não delegue à IA a decisão final sobre riscos ou prioridades, as sugestões iniciais de ameaças dependem da qualidade da descrição textual da história de usuário e da formulação do prompt empregado. Descrições incompletas ou ambíguas podem resultar na omissão de ameaças relevantes ou na geração de sugestões excessivamente genéricas. Além disso, modelos baseados em IA não garantem cobertura exaustiva de riscos e podem refletir vieses ou limitações decorrentes de seus dados de treinamento. Assim, o método pressupõe validação crítica e colaborativa das sugestões automatizadas, não substituindo o julgamento humano.

Adicionalmente, a estratégia metodológica prioriza a coleta de **evidências processuais e documentais**, como artefatos do backlog, registros de ameaças e decisões de segurança. Essa escolha favorece a objetividade, a rastreabilidade e a aderência ao fluxo ágil, mas pode limitar a exploração de percepções subjetivas dos participantes, aspectos culturais mais profundos ou fatores humanos não diretamente observáveis no processo. Tal limitação é coerente com os

desafios metodológicos relacionados à subjetividade e ao viés interpretativo destacados por Yin (2014).

Essas limitações não invalidam a pesquisa, mas definem o escopo da análise proposta e orientam a interpretação dos resultados que serão discutidos posteriormente. Embora essas limitações reduzam a capacidade de generalização dos resultados, elas são inerentes à natureza qualitativa e exploratória desta pesquisa. Estudos futuros poderão ampliar a investigação com múltiplos casos, equipes com diferentes níveis de maturidade em segurança e métodos complementares de coleta de dados que integrem aspectos subjetivos e culturais, aprofundando e validando as contribuições da abordagem CARCARÁ em contextos mais diversos.

4 RESULTADOS

Este capítulo apresenta os resultados da aplicação empírica do método CATM, conduzida por meio de um estudo de caso qualitativo em um projeto real de desenvolvimento de software no Tribunal de Justiça de Pernambuco (TJPE). A análise fundamenta-se em registros detalhados das cerimônias da Sprint 17, incluindo planejamento, acompanhamento diário, revisão e retrospectiva, sistematizados nos Apêndices D, E, F e G. Esses registros contemplam histórias de usuário analisadas, ameaças identificadas, ASPs criadas, decisões de segurança registradas e observações analíticas do pesquisador.

A análise baseou-se na observação direta das cerimônias ágeis, na inspeção dos artefatos produzidos e no acompanhamento das decisões documentadas no backlog. As evidências coletadas permitem caracterizar as formas pelas quais a modelagem de ameaças foi incorporada ao fluxo de desenvolvimento existente, sem a introdução de novos papéis ou rituais formais.

Os resultados do estudo de caso são apresentados de forma estruturada, tomando como referência as Questões de Pesquisa QP1, QP2 e QP3.

4.1 CONTEXTO DO ESTUDO DE CASO

O estudo de caso foi realizado em um projeto de software do Tribunal de Justiça de Pernambuco, desenvolvido sob a abordagem Scrum. O projeto era organizado em sprints iterativas, com cerimônias regulares de planejamento, acompanhamento diário, revisão e retrospectiva. A equipe era multidisciplinar, composta por desenvolvedores e um responsável pela coordenação funcional do sistema, sem a definição de papéis específicos voltados à segurança da informação.

A equipe do projeto era formada por dois desenvolvedores terceirizados (um em nível júnior e um em nível pleno), um profissional de DevOps em nível pleno e um gerente de projetos do quadro efetivo da instituição, com atuação voltada à coordenação das demandas e ao alinhamento com as necessidades de negócio. Embora esse papel não correspondesse formalmente à função de Product Owner (PO), na prática ele exercia responsabilidades associadas à priorização funcional do sistema.

No que se refere à segurança da informação, nenhum dos membros da equipe possuía formação especializada ou atuava em papéis dedicados à área. As decisões relacionadas a aspectos de segurança eram tradicionalmente tratadas de forma implícita, a partir da experiência

geral dos desenvolvedores e das demandas funcionais do sistema.

No estudo de caso analisado, o método CATM foi aplicado durante o planejamento de uma sprint específica (Sprint 17), com foco na análise das histórias de usuário priorizadas pela equipe. A unidade de análise correspondeu ao processo de planejamento ágil e aos artefatos de segurança produzidos a partir da aplicação da modelagem de ameaças. A observação foi complementada pela análise das cerimônias de acompanhamento, revisão e retrospectiva associadas a essa mesma sprint.

4.2 RESULTADOS DO ESTUDO DE CASO

Com o objetivo de oferecer uma visão sintética das evidências empíricas coletadas ao longo do estudo de caso, a Tabela 3 apresenta um panorama consolidado das manifestações da modelagem de ameaças nas diferentes cerimônias do Scrum observadas durante a Sprint 17. A tabela relaciona, para cada cerimônia, os principais artefatos, decisões e discussões de segurança identificados, bem como os respectivos registros empíricos que fundamentam a análise.

Essa síntese permite contextualizar os resultados apresentados nas subseções seguintes, facilitando a compreensão de como e em que momentos do fluxo ágil a segurança foi explicitamente incorporada, antes da análise detalhada orientada pelas Questões de Pesquisa QP1, QP2 e QP3.

Quadro 3 – Evidências empíricas por cerimônia (Sprint 17)

Cerimônia	Evidências observadas	Fonte
Sprint Planning	▪ Seleção de 2/4 histórias para modelagem de ameaças; ▪ Identificação de ameaças; ▪ Criação de 2 ASPs; ▪ Ajustes em critérios de aceitação.	Apêndice D
Daily Scrum	▪ ASPs tratadas como tarefas regulares; ▪ Menções pontuais; ▪ Sem novos riscos/ASPs.	Apêndice E
Sprint Review	▪ Validação das ASPs como concluídas; ▪ Demonstração de ajustes de erros/Application Programming Interface (API) e saneamento/CPF; ▪ Critérios de aceite de segurança verificados.	Apêndice F
Sprint Retrospective	▪ Benefícios percebidos (antecipação e previsibilidade); ▪ Dificuldades (dependência inicial do Threat Poker); ▪ Ajustes acordados para próximas sprints.	Apêndice G

4.2.1 Síntese quantitativa da aplicação do CATM na Sprint 17

Com o objetivo de consolidar as evidências empíricas observadas na aplicação do método CATM durante a Sprint 17, a Tabela 4 apresenta uma síntese quantitativa dos principais resultados obtidos. Essa consolidação permite visualizar, de forma objetiva, a relação entre histórias analisadas, ameaças identificadas e ações de segurança incorporadas ao backlog da sprint.

Tabela 4 – Síntese dos resultados observados na aplicação do CATM (Sprint 17)

Indicador observado	Quantidade
Histórias de usuário planejadas	4
Histórias submetidas à modelagem de ameaças	2
Ameaças identificadas	2
ASP criadas	2
Critérios de aceitação modificados	2
Ameaças registradas e não priorizadas	0

4.2.2 QP1 – Artefatos de segurança produzidos

Conforme demonstrado nos registros do Apêndice D, das quatro histórias de usuário inicialmente planejadas para a Sprint 17, duas (50%) foram selecionadas para a aplicação da modelagem de ameaças. Essas histórias envolviam integração com sistemas externos e manipulação de dados sensíveis.

A aplicação do CATM sobre esse subconjunto resultou na criação de duas ASPs, ambas classificadas com severidade alta e score ASP superior a 60, conforme apresentado na Tabela 5. Não foram criadas ASPs de baixo impacto, indicando uma seleção concentrada em riscos considerados relevantes pela equipe.

Além disso, foram produzidos os seguintes artefatos de segurança:

- cards de segurança associados às histórias de usuário analisadas;
- ASPs vinculadas ao backlog da sprint;
- ajustes nos critérios de aceitação das histórias de usuário;
- registro de ameaças cuja mitigação não foi priorizada no escopo da sprint.

A Tabela 4 apresenta a relação entre as histórias de usuário planejadas para a Sprint 17 e aquelas efetivamente submetidas à modelagem de ameaças.

Quadro 4 – Histórias planejadas e cobertura da modelagem de ameaças (Sprint 17)

ID	História	Modelagem?	ASPs
US01	Padronização do tratamento de exceções (API Error)	Sim	1
US02	Saneamento de dados para envio ao MNI	Sim	1
US03	Controle do Job de Etiquetagem PJe	Não	0
US04	Padronização de tipos de arquivos (MIME types)	Não	0

A Tabela 5 detalha a associação entre as histórias analisadas e as respectivas ASPs geradas. A identificação das ameaças foi realizada a partir do uso do CTP, conforme registrado nos Apêndices H e I, e resultou na derivação de ASPs específicas.

Quadro 5 – Histórias de usuário analisadas e ASPs geradas na Sprint 17

ID	História de Usuário	Ameaça Identificada	ASP Criada
US01	Padronização do tratamento de exceções (API Error)	Exposição de informações internas em mensagens de erro da API	ASP-17-01: Padronizar respostas de erro com ApiError, evitando vazamento de dados internos
US02	Saneamento de dados para envio ao MNI	Injeção de caracteres inválidos e falha de validação de CPF em arquivos enviados	ASP-17-02: Saneamento de nomes de arquivos e validação de CPF antes da integração com MNI

4.2.3 QP2 – Decisões de segurança produzidas

A aplicação da modelagem de ameaças influenciou diretamente as decisões de segurança registradas ao longo do ciclo de desenvolvimento. As decisões observadas foram documentadas em artefatos formais do Scrum, como o backlog da sprint e os critérios de aceitação das histórias de usuário.

Conforme registrado no Apêndice D, as discussões resultaram em três tipos principais de decisões:

- inclusão das ASPs ASP-17-01 e ASP-17-02 no backlog da sprint;
- modificação dos critérios de aceitação das histórias US01 e US02, para incorporar os aspectos de segurança discutidos;
- descarte consciente de ameaças cuja mitigação foi considerada fora do escopo da sprint.

As modificações nos critérios de aceitação foram resultado direto da aplicação do CATM sobre as histórias US01 e US02, conforme registrado nos Apêndices D e F.

A Tabela 6 apresenta a evolução dos critérios de aceitação dessas histórias antes e depois da modelagem de ameaças na Sprint 17. Os critérios iniciais refletiam requisitos funcionais básicos, sem considerações explícitas de segurança.

A aplicação do método CATM permitiu identificar riscos associados, o que levou à inclusão de critérios voltados à prevenção de vazamento de informações (US01) e à validação de dados sensíveis (US02). Essas alterações foram incorporadas diretamente aos critérios de aceite, fortalecendo o vínculo entre a análise de ameaças e a definição dos incrementos de software.

Quadro 6 – Evolução dos critérios de aceitação após a modelagem de ameaças

História	Antes da modelagem	Após modelagem
US01	Mensagens de erro devem ser padronizadas e compreensíveis	As mensagens devem usar o padrão <code>ApiError</code> e não devem revelar detalhes técnicos ou stack traces
US02	Arquivos devem ser enviados ao MNI com CPF informado no payload	Nomes de arquivos devem ser saneados para evitar injeção; CPF deve ser validado antes do envio

É relevante destacar que, no momento do planejamento, a seleção das histórias US01 e US02 não foi motivada por preocupações de segurança, mas por critérios técnicos e funcionais. No entanto, o contexto dessas histórias revelou-se propício à análise de ameaças, permitindo a identificação de riscos relevantes. Como consequência, as ASPs derivadas foram percebidas como pertinentes e integradas naturalmente ao planejamento da sprint.

Quadro 7 – Ameaças identificadas, classificação e esforço de mitigação (Sprint 17)

ID	Ameaça Identificada	Classificação (STRIDE)	CWE Associado	Risco Estimado	Esforço de Mitigação
US01	Exposição de informações internas em mensagens de erro da API	Information Disclosure	CWE-209: Information Exposure Through an Error Message	Alto	Baixo
US02	Falha na validação de CPF e nomes de arquivos com caracteres inválidos	Tampering / Input Validation	CWE-116: Improper Encoding or Escaping of Output CWE-20: Improper Input Validation	Alto	Médio

A Tabela 7 apresenta uma síntese das ameaças identificadas nas histórias de usuário analisadas durante a Sprint 17, com sua respectiva categorização segundo o modelo STRIDE, associação com CWE, estimativa de risco e esforço de mitigação. No caso da história US01, a exposição de informações internas em mensagens de erro foi classificada como uma ameaça do tipo *Information Disclosure* e associada à CWE-209, que trata da exposição de dados sensíveis por meio de mensagens de erro. O risco foi considerado alto, devido à possibilidade

de vazamento de detalhes técnicos, mas o esforço de mitigação foi avaliado como baixo, uma vez que a solução envolvia a aplicação de um padrão já existente no sistema (ApiError).

Já na história US02, foram identificadas ameaças relacionadas à manipulação de dados de entrada (*Tampering*) e à ausência de validação adequada de CPF e nomes de arquivos. Essas ameaças foram associadas às fraquezas CWE-116 e CWE-20, relacionadas ao tratamento incorreto e à validação inadequada de entradas. O risco também foi considerado alto, especialmente por se tratar de dados enviados a um sistema externo Modelo Nacional de Interoperabilidade (MNI), e o esforço de mitigação foi classificado como médio, dado que exigiu ajustes no processo de integração e verificação adicional dos dados enviados.

Essas informações permitiram que as ameaças fossem tratadas de forma explícita no planejamento da sprint, orientando a definição de ASPs adequadas ao risco estimado e compatíveis com o esforço disponível da equipe.

A efetividade das decisões foi confirmada durante a Sprint Review (Apêndice F), com a demonstração funcional das ASPs concluídas e a verificação dos critérios de segurança definidos, sem registro de retrabalho ou renegociação.

4.3 QP3 – COMO A INTEGRAÇÃO DA MODELAGEM DE AMEAÇAS IMPACTA O FLUXO ÁGIL DE DESENVOLVIMENTO?

Esta questão de pesquisa investiga como a introdução da modelagem de ameaças afeta o processo de desenvolvimento no contexto do framework Scrum. O objetivo é compreender se há alterações nas cerimônias, na dinâmica da equipe e na visibilidade das decisões de segurança.

A aplicação do método CATM não resultou na criação de novos papéis, cerimônias ou fases formais no framework Scrum adotado pelo projeto. As mudanças observadas ocorreram principalmente na forma como as cerimônias passaram a ser conduzidas, incorporando discussões relacionadas à segurança de forma natural e sem fricção.

A Figura 5 ilustra o fluxo tradicional das cerimônias do Scrum e destaca, em **negrito**, os pontos em que a segurança passou a ser abordada de forma explícita ou implícita após a introdução da modelagem de ameaças.

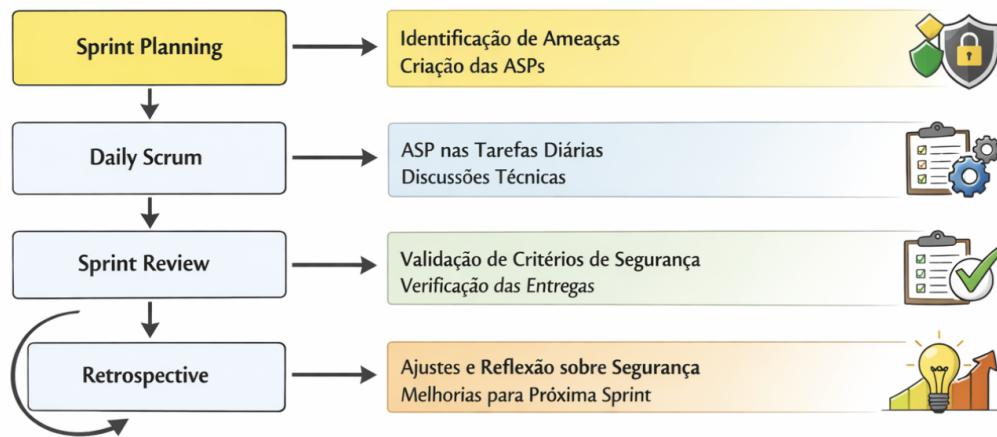


Figura 5 – Integração da modelagem de ameaças às cerimônias do Scrum

A principal mudança foi observada durante a Sprint Planning (Apêndice D), quando a análise das histórias de usuário passou a incluir a identificação de ameaças antes do início da implementação. Como exemplificado previamente, a história **US01** teve seu critério de aceitação ajustado após a identificação, via CTP, de risco de exposição de informações técnicas em mensagens de erro (CWE-209). Essa decisão teve impacto direto no fluxo de desenvolvimento, exigindo a aplicação consistente do padrão `ApiError`.

De forma semelhante, a história **US02** passou a exigir sanitização de nomes de arquivos e validação de CPF, após a análise de riscos ligados às fraquezas CWE-116 e CWE-20. Isso implicou ajustes técnicos durante a sprint, como a criação de uma função de normalização Formato de Transformação Unicode de 8 bits (UTF-8) e validação de dados sensíveis.

Essas mudanças foram incorporadas ao backlog como ASPs e trataram-se de decisões diretamente derivadas da modelagem de ameaças. A Tabela 8 sintetiza os impactos observados no fluxo ágil para cada uma das histórias analisadas.

Quadro 8 – Impactos da modelagem de ameaças no fluxo ágil por história de usuário

ID	Mudança nos critérios de aceitação	Impacto no desenvolvimento	Validação na Review
US01	Inclusão de exigência de uso do padrão <code>ApiError</code> e proibição de exposição de detalhes técnicos	Implementação de mecanismo padronizado de erro; prevenção de vazamento de informações	Foram testadas falhas simuladas; nenhuma informação técnica foi exposta
US02	Sanitização de nomes de arquivos e validação de CPF antes do envio ao MNI	Criação de função para normalizar nomes; tratamento de codificações UTF-8 e rejeição de CPFs inválidos	Validação com arquivos contendo caracteres acentuados e CPFs malformados

Durante os encontros de **Daily Scrum** (Apêndice E), essas ASPs foram tratadas como tarefas comuns do backlog, mas geraram discussões pontuais. Em particular, um dos desenvolvedores relatou dificuldade técnica na sanitização de nomes de arquivos com codificações e caracteres especiais, resultando na criação de uma subtarefa específica para implementar um módulo de normalização compatível com UTF-8 e com as restrições do sistema de destino.

Na **Sprint Review** (Apêndice F), os critérios de aceitação de segurança foram utilizados como referência para validar as entregas. No caso da US01, foram testadas mensagens de erro geradas a partir de falhas intencionais, confirmando que nenhuma informação técnica era exposta. Já na US02, foram testados nomes de arquivos com caracteres acentuados e CPFs inválidos, sendo verificado que o sistema respondia adequadamente.

Durante a **Retrospective** (Apêndice G), a equipe refletiu sobre a utilidade prática da antecipação das decisões de segurança. A principal mudança acordada foi incorporar, de forma permanente, a análise leve de ameaças ao planejamento das próximas sprints, utilizando o **Carcará Threat Poker** como instrumento de apoio.

Essas evidências indicam que a introdução da modelagem de ameaças se manifestou de forma mais explícita durante o **Sprint Planning**, enquanto nas demais cerimônias a segurança foi incorporada de maneira implícita, integrada ao fluxo regular de acompanhamento e validação das entregas. Essa integração ocorreu por meio da adaptação das práticas já existentes, sem necessidade de introdução de novos papéis ou mudanças estruturais no processo Scrum.

4.4 APLICABILIDADE DO MÉTODO EM OUTROS CONTEXTOS

Embora o método CATM tenha sido aplicado neste estudo em uma única equipe e em uma sprint específica, sua estrutura conceitual permite adaptação a outros contextos organizacionais.

Em ambientes com múltiplas squads, a mecânica do CTP pode ser aplicada de forma descentralizada durante o *Sprint Planning* de cada equipe, mantendo a autonomia local. A consolidação de ASPs priorizadas pode, nesse cenário, ser acompanhada em nível de programa ou portfólio, permitindo visibilidade transversal de riscos recorrentes.

Em organizações de maior porte ou com estruturas escaladas, como ambientes que adotam modelos inspirados no SAFe, o modelo de priorização baseado em $R \times EM$ pode ser integrado a mecanismos já existentes de priorização, como o WSJF, atuando como critério complementar específico para riscos de segurança.

Adicionalmente, em equipes com especialistas dedicados em segurança, o CTP pode

assumir papel mais estruturado, funcionando como mecanismo de facilitação colaborativa entre desenvolvedores e profissionais de segurança, reduzindo assimetrias de conhecimento.

Todavia, a aplicabilidade em contextos distintos pode exigir ajustes na escala de avaliação de risco, na forma de consolidação das ASPs e na governança das decisões de segurança, aspectos que devem ser considerados conforme a maturidade organizacional e o modelo de gestão adotado.

5 DISCUSSÃO

Este capítulo discute os resultados obtidos no estudo de caso à luz da literatura analisada e dos objetivos desta pesquisa. Diferentemente do capítulo de Resultados, que apresentou de forma descritiva as evidências empíricas coletadas, a Discussão tem como propósito interpretar criticamente esses resultados, relacionando-os às lacunas identificadas na Revisão Rápida da Literatura e analisando suas implicações para a integração da modelagem de ameaças em contextos ágeis.

A discussão enfatiza não apenas os benefícios observados com a aplicação do método **Carcará Agile Threat Modeling (CATM)**, mas também suas limitações conceituais, operacionais e metodológicas, reconhecendo os compromissos assumidos ao se propor uma abordagem deliberadamente leve de modelagem de ameaças.

5.1 INTEGRAÇÃO DA MODELAGEM DE AMEAÇAS AO PLANEJAMENTO ÁGIL

Os resultados do estudo de caso indicam que a modelagem de ameaças pode ser integrada ao planejamento ágil sem a introdução de novos papéis, artefatos ou cerimônias formais. Essa característica responde diretamente às barreiras de adoção recorrentemente identificadas na literatura, que apontam resistência organizacional à incorporação de práticas de segurança percebidas como disruptivas, burocráticas ou excessivamente especializadas.

Esse resultado está em consonância com Phanireddy (2025), que argumenta que a efetividade da modelagem de ameaças em ambientes ágeis depende da sua capacidade de adaptação às cerimônias existentes, como o *Sprint Planning*, evitando sobrecarga ou resistência por parte da equipe.

A concentração da aplicação do CATM no *Sprint Planning* revela uma estratégia de integração alinhada ao fluxo natural do Scrum, permitindo que a discussão de riscos ocorra no momento em que histórias de usuário são analisadas, priorizadas e detalhadas. Essa escolha favorece a viabilidade prática da proposta, especialmente em equipes que operam sob restrições de tempo, recursos e maturidade em segurança.

Entretanto, essa mesma decisão implica um foco predominante da segurança no planejamento, o que limita sua presença explícita nas demais cerimônias ágeis, como *Daily Scrum*, *Sprint Review* e *Retrospective*. Embora as decisões tomadas no planejamento influenciem indiretamente essas etapas, o método, em sua forma atual, não estrutura mecanismos específicos

para sustentar a discussão contínua de segurança ao longo de toda a sprint.

5.2 ARTEFATOS LEVES E RASTREABILIDADE DAS DECISÕES DE SEGURANÇA

A produção de artefatos de segurança leves e integrados ao backlog, como *Atividades de Segurança Proativas (ASP)* e ajustes em critérios de aceitação, representa uma alternativa pragmática às abordagens tradicionais de modelagem de ameaças baseadas em documentação extensa e especializada.

Esses artefatos mostraram-se adequados para registrar riscos, decisões e ações de mitigação de forma compatível com os instrumentos já utilizados pelas equipes ágeis, preservando a rastreabilidade das decisões de segurança sem introduzir sobrecarga processual. Enquanto abordagens tradicionais como a descrita por Shostack (2014) enfatizam o uso extensivo de diagramas e formalismos para identificação e tratamento de ameaças, os artefatos leves adotados no CATM, como ASPs e critérios de aceitação ajustados, dialogam com os princípios identificados por Mihelič et al. (2024), que destacam a necessidade de soluções mais pragmáticas e ajustadas à realidade de equipes pequenas ou com baixa maturidade em segurança.

Por outro lado, a adoção de artefatos leves implica a renúncia deliberada a elementos tradicionalmente associados à modelagem de ameaças clássica, como diagramas de fluxo de dados, listas explícitas de ativos, definição formal de perímetros e mapeamento detalhado de superfícies de ataque. Esses artefatos, que desempenham papel central em métodos tradicionais de modelagem, não são produzidos no contexto do CATM.

Essa ausência não decorre de uma limitação acidental do método, mas de uma escolha consciente de escopo. O CATM não se propõe a substituir a modelagem de ameaças tradicional, mas a atuar como uma introdução estruturada ao raciocínio de segurança no contexto ágil, privilegiando a incorporação precoce da perspectiva de risco em detrimento da completude analítica típica de abordagens mais formais.

5.3 CARCARÁ THREAT POKER COMO INSTRUMENTO DE APOIO À PERCEPÇÃO DE RISCOS

O uso do *Carcará Threat Poker (CTP)* como instrumento de apoio mostrou-se eficaz para estimular a percepção coletiva de riscos associados às histórias de usuário, especialmente em equipes sem formação especializada em segurança. O instrumento auxilia na identificação de ameaças potenciais e na ampliação do repertório de riscos considerados durante o planejamento.

Dawoud et al. (2024) reforçam a importância da sensibilização precoce para riscos, por meio de práticas colaborativas integradas ao fluxo de desenvolvimento. O uso do CTP, neste estudo, funcionou como catalisador para esse tipo de discussão, promovendo alinhamento e conscientização em equipes sem especialistas em segurança.

Contudo, o CTP não produz os artefatos tradicionais da modelagem de ameaças, nem oferece garantias de exaustividade na identificação de riscos. Seu papel é essencialmente consultivo e pedagógico, funcionando como um catalisador para a discussão de segurança, e não como um mecanismo completo de análise estruturada de ameaças.

Dessa forma, o instrumento contribui para a sensibilização e para a introdução da segurança no processo decisório ágil, mas não elimina a necessidade de abordagens mais profundas em contextos que demandem análises de risco rigorosas, auditorias formais ou conformidade regulatória estrita.

5.4 LIMITAÇÕES DAS ATIVIDADES DE SEGURANÇA PROATIVAS (ASP)

As *Atividades de Segurança Proativas (ASP)* constituem um dos elementos centrais da proposta, ao traduzirem recomendações de segurança em unidades acionáveis no backlog. No entanto, sua eficácia depende da capacidade da equipe em avaliar adequadamente risco e esforço, o que pode representar um desafio em contextos de baixa maturidade em segurança.

Essa limitação também é destacada por Núñez, Lindo e Rodríguez (2020), que aponta a dificuldade de estimar riscos com precisão em equipes sem bases técnicas sólidas, o que pode comprometer a priorização adequada das ações de mitigação.

Existe o risco de que desenvolvedores, ao carecerem de parâmetros técnicos mais robustos para estimar a complexidade de uma atividade de segurança, atribuam pesos inadequados às ASPs. Nesse cenário, a recomendação gerada por instrumentos de apoio baseados em inteligência artificial pode assumir papel excessivamente central no processo decisório, deslocando o julgamento crítico da equipe.

Além disso, a avaliação de risco associada a uma ASP pode ser superestimada ou subestimada em função da ausência de contexto arquitetural detalhado, como ativos, perímetros e fluxos de dados. Essa limitação reforça o caráter aproximativo das ASPs e indica a necessidade de calibração contínua do método à medida que a maturidade da equipe em segurança evolui.

5.5 EXPLICITAÇÃO E FORMALIZAÇÃO DAS DECISÕES DE SEGURANÇA

Apesar das limitações identificadas, os resultados indicam que a aplicação do CATM contribui de forma significativa para tornar explícitas decisões de segurança que, em muitos contextos ágeis, permanecem implícitas ou informais. A formalização dessas decisões no backlog e nos critérios de aceitação favorece a transparência, a rastreabilidade e a possibilidade de revisão posterior.

Esse aspecto é particularmente relevante em ambientes onde decisões relacionadas à aceitação de risco são frequentemente tomadas de forma tácita, sem registro ou discussão estruturada. Ao transformar recomendações de segurança em elementos visíveis do processo ágil, o método promove maior responsabilidade compartilhada entre os membros da equipe.

Essa importância da visibilidade também é reforçada por Larios-Vargas et al. (2023), que apontam a formalização das decisões de segurança como um fator-chave para promover mudanças comportamentais nas equipes e aumentar a adoção de práticas seguras no cotidiano do desenvolvimento.

5.6 IMPLICAÇÕES PARA EQUIPES SEM ESPECIALISTAS EM SEGURANÇA

O contexto analisado, caracterizado pela ausência de profissionais dedicados à segurança da informação, é representativo de uma parcela significativa dos projetos de software. Os resultados sugerem que o CATM pode atuar como um mecanismo de redução da assimetria de conhecimento, oferecendo suporte estruturado para a identificação e discussão de riscos.

Entretanto, essa característica também delimita o alcance do método. O CATM não elimina a necessidade de especialistas em segurança em cenários de alta criticidade, mas oferece uma alternativa viável para equipes que buscam incorporar práticas mínimas de segurança de forma progressiva, sem comprometer o ritmo de entrega.

Esse resultado converge com as evidências apresentadas por Mihelič et al. (2024), que propõem abordagens incrementais e situacionais para segurança em pequenas e médias empresas, reforçando que soluções leves podem gerar impacto significativo mesmo sem especialistas dedicados.

5.6.0.1 *Esforço cultural na adoção do CATM*

Os resultados do estudo de caso indicam que a incorporação da segurança ao fluxo ágil envolve mudanças culturais que se manifestam diretamente no cotidiano das equipes de

desenvolvimento.

Observou-se que a introdução do CATM promoveu:

- **Discussão explícita de ameaças no planejamento:** durante o *Sprint Planning*, as histórias passaram a incluir discussões estruturadas sobre riscos de segurança, incentivando a participação ativa da equipe na identificação de ameaças.
- **Integração da segurança aos critérios de aceitação:** requisitos de segurança foram incorporados diretamente às histórias de usuário, reduzindo a separação entre desenvolvimento e segurança.
- **Redução da carga cognitiva:** o uso de mecanismos estruturados, como o Carcará Threat Poker, contribuiu para tornar a identificação de ameaças mais acessível e menos dependente de conhecimento especializado.
- **Aproximação entre segurança e contexto funcional:** a utilização de uma linguagem mais próxima do domínio de negócio facilitou o entendimento dos riscos e favoreceu o engajamento da equipe.

Esses achados reforçam a literatura que aponta fatores culturais e cognitivos como determinantes para a adoção de práticas de segurança (Larios-Vargas et al., 2023), evidenciando que a redução de fricção no fluxo de trabalho é um elemento central para a efetividade da segurança em ambientes ágeis.

5.7 CONTRIBUIÇÕES DO TRABALHO

Além da avaliação empírica apresentada no capítulo anterior, este trabalho oferece contribuições relevantes para a academia, a indústria de software e a sociedade, ao propor e analisar criticamente uma abordagem metodológica leve de integração da modelagem de ameaças ao planejamento ágil.

5.7.1 Contribuições para a academia

Do ponto de vista acadêmico, este trabalho contribui para o campo da Engenharia de Software Segura ao avançar na discussão sobre a operacionalização da segurança em contextos ágeis. A literatura ressalta que, embora existam frameworks consolidados, persistem lacunas na tradução desses modelos para práticas cotidianas compatíveis com o Scrum.

A principal contribuição acadêmica reside na proposição do método CATM como uma adaptação leve, empiricamente observável e conceitualmente delimitada da modelagem de ameaças, posicionada não como substituta, mas como complemento introdutório às abordagens tradicionais.

5.7.2 Contribuições para a indústria

No contexto industrial, o trabalho oferece uma proposta aplicável a equipes que enfrentam restrições comuns, como limitação de tempo, ausência de especialistas em segurança e pressão por entregas contínuas. O estudo de caso demonstra que é possível incorporar a discussão de riscos ao planejamento ágil sem aumento significativo de fricção operacional.

Entretanto, a adoção efetiva de práticas como as propostas pelo CATM não depende apenas de instrumentos técnicos, mas também de aspectos culturais e organizacionais. A incorporação da segurança ao planejamento ágil pressupõe que desenvolvedores passem a considerar riscos de segurança como parte integrante da definição e implementação de funcionalidades. Nesse sentido, a aplicação do método também demanda um esforço de conscientização e maturidade organizacional, alinhado aos princípios do DevSecOps, nos quais a segurança é tratada como responsabilidade compartilhada entre os membros da equipe.

Embora o CATM tenha sido concebido como uma abordagem leve, sua adoção pode implicar um período inicial de adaptação pelas equipes. A familiarização com taxonomias de segurança, como OWASP Top 10 e CWE, pode aumentar temporariamente o tempo dedicado ao planejamento da sprint. Entretanto, espera-se que esse impacto seja reduzido à medida que a equipe se familiariza com o processo e passa a incorporar a discussão de riscos como parte natural do planejamento ágil, reduzindo gradualmente a sobrecarga cognitiva associada à identificação de ameaças.

5.7.3 Contribuições para a sociedade

Sob a perspectiva social, a principal contribuição deste trabalho está associada à promoção do desenvolvimento de software mais seguro em contextos onde falhas de segurança impactam diretamente usuários finais e serviços críticos. Ao facilitar a incorporação antecipada da segurança, o método contribui para a redução de vulnerabilidades e para a formação de uma cultura de segurança mais consciente e acessível.

6 AMEAÇAS À VALIDADE

Este capítulo discute as principais ameaças à validade da pesquisa, considerando o desenho metodológico adotado, o uso de uma Revisão Rápida da Literatura e a avaliação empírica do método CATM por meio de um estudo de caso qualitativo. A explicitação dessas ameaças tem como objetivo delimitar o alcance dos resultados obtidos e apoiar uma interpretação crítica das evidências apresentadas.

As ameaças são organizadas de acordo com categorias tradicionalmente adotadas em pesquisas empíricas em Engenharia de Software: validade de construção, validade interna, validade externa e validade de confiabilidade.

6.1 VALIDADE DE CONSTRUÇÃO

A validade de construção refere-se ao grau em que os conceitos teóricos investigados são adequadamente operacionalizados por meio dos instrumentos e procedimentos adotados na pesquisa.

Uma potencial ameaça está relacionada à operacionalização do conceito de *integração da modelagem de ameaças ao processo ágil*. Neste trabalho, esse conceito foi observado por meio de evidências processuais e documentais, tais como artefatos do backlog, registros de ameaças, ASP e decisões discutidas nas cerimônias do Scrum. Embora esses artefatos sejam compatíveis com o objetivo da pesquisa, eles representam apenas uma parte das dimensões possíveis da integração de segurança, não capturando, por exemplo, percepções individuais ou mudanças cognitivas dos participantes.

Outra ameaça decorre do uso do instrumento CTP como apoio à modelagem de ameaças. Embora o instrumento tenha sido utilizado como mecanismo consultivo, sua presença pode ter influenciado a forma como as ameaças foram identificadas e discutidas. Para mitigar esse risco, o instrumento foi tratado explicitamente como apoio à discussão, sem caráter decisório, e as decisões de segurança permaneceram sob responsabilidade da equipe.

6.2 VALIDADE INTERNA

A validade interna está associada à relação causal entre a aplicação do método CATM e os efeitos observados no fluxo de desenvolvimento.

Uma ameaça relevante diz respeito à possibilidade de fatores externos terem influenciado os resultados observados, como a experiência prévia dos membros da equipe, pressões de prazo ou decisões organizacionais independentes da aplicação do método. Como se trata de um estudo de caso qualitativo, não é possível isolar completamente essas variáveis.

Além disso, o pesquisador atuou como observador participante com intervenção mínima, o que pode introduzir viés de observação ou interpretação. Esse risco foi mitigado por meio da delimitação clara do papel do pesquisador, que não participou das decisões técnicas ou de priorização, e pela ênfase em evidências documentais e registros observáveis no fluxo de desenvolvimento.

6.3 VALIDADE EXTERNA

A validade externa refere-se ao grau em que os resultados podem ser generalizados para outros contextos, equipes ou organizações.

O estudo de caso foi conduzido em um único projeto de software, inserido em uma organização pública específica, com uma equipe enxuta e sem especialistas dedicados em segurança da informação. Dessa forma, os resultados não visam à generalização estatística, mas à generalização analítica, contribuindo para a compreensão do fenômeno investigado e para a reflexão teórica sobre a integração da modelagem de ameaças em contextos ágeis.

As características organizacionais do contexto analisado, como o uso de equipe terceirizada e a ausência de papéis formais de segurança, podem limitar a transferibilidade direta dos resultados para ambientes com estruturas mais maduras ou com equipes dedicadas à segurança. Ainda assim, esses mesmos fatores reforçam a relevância do estudo para contextos semelhantes, comuns em projetos públicos e organizações com restrições de recursos.

6.4 VALIDADE DE CONFIABILIDADE

A validade de confiabilidade está relacionada à possibilidade de replicação do estudo e à consistência dos procedimentos adotados.

Uma ameaça potencial decorre do caráter qualitativo da análise e da dependência de registros observacionais. Para mitigar esse risco, a pesquisa utilizou um instrumento de coleta estruturado, descrito nos apêndices, e manteve registros documentais sistemáticos das cerimônias observadas, das histórias de usuário analisadas e dos artefatos de segurança produzidos.

Adicionalmente, o método CATM foi descrito de forma explícita e estruturada ao longo do trabalho, incluindo seus princípios, atividades e mecanismos de integração ao Scrum. Essa descrição visa favorecer a reprodutibilidade analítica do estudo, ainda que os resultados empíricos possam variar em função do contexto organizacional e da equipe envolvida.

7 CONCLUSÃO

Este trabalho apresentou o método *CARCARÁ Agile Threat Modeling (CATM)* como resposta às lacunas identificadas na literatura quanto à operacionalização prática da modelagem de ameaças em contextos ágeis. A análise teórica evidenciou desafios recorrentes, como a complexidade de frameworks tradicionais, a resistência cultural das equipes, a sobrecarga cognitiva associada à identificação de riscos e a dificuldade de traduzir ameaças em unidades acionáveis no backlog.

A partir desses achados, foi concebido um artefato metodológico estruturado para integrar a discussão de riscos diretamente ao planejamento da sprint, preservando a dinâmica do Scrum. O método organiza-se em dois componentes complementares: (i) as *Atividades de Segurança Proativas (ASP)*, que formalizam a conversão de ameaças em unidades prioritáveis com base na combinação entre risco e esforço de mitigação; e (ii) o *Carcará Threat Poker (CTP)*, instrumento colaborativo apoiado por IA consultiva que estrutura a identificação e discussão de riscos no nível das histórias de usuário.

A avaliação empírica, conduzida por meio de estudo de caso qualitativo em contexto organizacional real, indicou que o CATM viabiliza a explicitação, priorização e rastreabilidade de decisões de segurança no backlog, sem introduzir alterações estruturais no framework Scrum. As mudanças observadas caracterizaram-se como ajustes incrementais no fluxo existente, evidenciando a viabilidade operacional da proposta.

Os resultados observados neste estudo de caso devem ser interpretados à luz das limitações metodológicas inerentes ao desenho da pesquisa. A investigação foi conduzida em um único contexto organizacional e não incluiu métricas comparativas ou baseline estatístico que permitissem avaliar quantitativamente ganhos de desempenho. Dessa forma, os achados devem ser compreendidos como evidências qualitativas sobre a viabilidade de integração da modelagem de ameaças ao fluxo do Scrum, e não como prova de melhoria mensurável de desempenho.

Contribuições acadêmicas

Do ponto de vista acadêmico, este trabalho contribui ao propor e avaliar empiricamente um artefato metodológico leve para modelagem de ameaças no nível das histórias de usuário, integrando-a diretamente ao planejamento da sprint no contexto do Scrum. A formalização das Atividades de Segurança Proativas (ASP), com priorização baseada na combinação entre

risco e esforço de mitigação, constitui uma contribuição conceitual ao aproximar análise de risco e gestão de backlog em ambientes ágeis.

Além disso, o estudo oferece evidências empíricas iniciais sobre a viabilidade de integrar a modelagem de ameaças ao Scrum sem introdução de novos papéis ou cerimônias, contribuindo para a discussão acadêmica sobre segurança em contextos ágeis.

Contribuições práticas

Sob a perspectiva prática, o método CARCARÁ oferece às equipes ágeis um mecanismo estruturado para incorporar decisões de segurança diretamente ao backlog da sprint em contextos com restrições de tempo e ausência de especialistas dedicados em segurança. A conversão explícita de ameaças em atividades rastreáveis no backlog permite maior transparência e rastreabilidade das decisões de segurança.

O uso do Carcará Threat Poker como instrumento colaborativo, com apoio consultivo de inteligência artificial, demonstra uma alternativa viável para estruturar discussões de risco no planejamento da sprint sem gerar sobrecarga processual.

TRABALHOS FUTUROS

A partir dos resultados obtidos nesta pesquisa, abrem-se possibilidades relevantes para investigações futuras.

Além da replicação em contextos distintos, torna-se pertinente examinar a aplicabilidade do CATM em estruturas organizacionais mais complexas, como ambientes com múltiplas squads, projetos distribuídos ou organizações de maior porte. Nesses cenários, podem surgir desafios adicionais relacionados à padronização das escalas de risco e esforço, à governança do uso da IA consultiva e à consolidação de indicadores de segurança em nível organizacional.

A adoção do método em múltiplas equipes pode demandar mecanismos complementares de coordenação, como diretrizes mínimas para calibragem do cálculo do ASP, integração com ferramentas corporativas de gestão de backlog e definição de políticas internas para uso consistente do instrumento de apoio. A análise dessas adaptações permitirá avaliar a escalabilidade do modelo e sua viabilidade em ambientes de maior complexidade estrutural.

Destacam-se ainda as seguintes possibilidades de aprofundamento:

- replicação do estudo de caso em múltiplos projetos e contextos organizacionais, ampliando a generalização analítica dos resultados;

- condução de estudos longitudinais para avaliar a consolidação das práticas propostas ao longo de várias sprints;
- integração técnica do CATM com ferramentas de gestão de backlog e pipelines DevSecOps;
- análise do impacto do método em métricas de segurança e qualidade de software.

REFERÊNCIAS

- AHMAD, M. O.; GUSTAVSSON, T.; SAEEDA, H. Customised roles in scrum teams for the development of secure solution. In: **2023 49th Euromicro Conference on Software Engineering and Advanced Applications (SEAA)**. [S.l.: s.n.], 2023. p. 362–369. ISSN 2376-9521.
- AKBAR, M. A.; ALSANAD, A. A. Empirical investigation of key enablers for secure devops practices. **IEEE Access**, v. 13, p. 43698–43715, 2025. ISSN 2169-3536.
- ALJOHANI, M. A.; ALQAHTANI, S. S. A unified framework for automating software security analysis in devsecops. In: **2023 International Conference on Smart Computing and Application (ICSCA)**. [S.l.: s.n.], 2023. p. 1–6.
- BEKTUROVA, A. et al. Defender-attacker model based secure software development lifecycle for common web vulnerabilities. In: **2023 IEEE International Conference on Smart Information Systems and Technologies (SIST)**. [S.l.: s.n.], 2023. p. 272–277.
- BOLISH, S. et al. Building cyber resilient systems from day 1. In: **2024 IEEE Aerospace Conference**. [S.l.: s.n.], 2024. p. 1–8. ISSN 1095-323X.
- DAWOUD, A. et al. Better left shift security! framework for secure software development. In: **2024 IEEE European Symposium on Security and Privacy Workshops (EuroS&PW)**. [S.l.: s.n.], 2024. p. 642–649. ISSN 2768-0657.
- GRANT, M. J.; BOOTH, A. A typology of reviews: an analysis of 14 review types and associated methodologies. **Health Information & Libraries Journal**, Wiley, v. 26, n. 2, p. 91–108, 2009.
- HASTINGS, T.; WALCOTT, K. R. Continuous verification of open source components in a world of weak links. In: **2022 IEEE International Symposium on Software Reliability Engineering Workshops (ISSREW)**. [S.l.: s.n.], 2022. p. 201–207.
- JIANG, S.; ZHANG, Y.; WANG, Z. A dynamic cvss-based risk scoring model for software vulnerability prioritization. **Computers & Security**, Elsevier, v. 118, p. 102740, 2022.
- JOSHI, H. A secure software development methodology for enterprise business applications. In: **2024 IEEE International Conference on Data and Software Engineering (ICoDSE)**. [S.l.: s.n.], 2024. p. 7–12. ISSN 2640-0227.
- LARIOS-VARGAS, E. et al. Dasp: A framework for driving the adoption of software security practices. **IEEE Transactions on Software Engineering**, v. 49, n. 4, p. 2892–2919, April 2023. ISSN 1939-3520.
- MAUW, S.; OOSTDIJK, M. Foundations of attack trees. In: **Information Security and Cryptology (ICISC 2005)**. [S.l.: Springer, 2006. (Lecture Notes in Computer Science, v. 3935), p. 186–198.
- Microsoft. **Uncover Security Design Flaws Using The STRIDE Approach**. 2006. <https://learn.microsoft.com/en-us/archive/msdn-magazine/2006/november/uncover-security-design-flaws-using-the-stride-approach>. Acessado em 30/09/2025.

Microsoft. **The Security Development Lifecycle**. 2009. <https://learn.microsoft.com/en-us/compliance/assurance/assurance-microsoft-security-development-lifecycle>. Acessado em 25/09/2025.

MIHELIČ, A. et al. Delegation-based agile secure software development approach for small and medium-sized businesses. **IEEE Access**, v. 12, p. 189611–189635, 2024. ISSN 2169-3536.

NIKOLOV, L. A.; ALEKSIEVA-PETROVA, A. P. Action research on the devsecops pipeline. In: **2023 International Scientific Conference on Computer Science (COMSCI)**. [S.l.: s.n.], 2023. p. 1–6.

Núñez, J. C. S.; LINDO, A. C.; RODRÍGUEZ, P. G. A preventive secure software development model for a software factory: A case study. **IEEE Access**, v. 8, p. 77653–77665, 2020. ISSN 2169-3536.

PHANIREDDY, S. A forward-thinking secure software development: Threat modeling in web application security. **Journal of Artificial Intelligence, Machine Learning and Data Science**, v. 3, n. 1, p. 2330–2340, 2025. ISSN 2583-9888.

Scaled Agile, Inc. **Weighted Shortest Job First (WSJF)**. 2023. <https://scaledagileframework.com/wsjf/>. Acessado em 07/02/2026.

SCHWABER, K.; SUTHERLAND, J. **The Scrum Guide: The Definitive Guide to Scrum: The Rules of the Game**. 2020. <https://scrumguides.org/scrum-guide.html>. Acesso em: 18 dez. 2025.

SHOSTACK, A. **Threat Modeling: Designing for Security**. Indianapolis, IN: Wiley, 2014. ISBN 978-1-118-80099-1. Disponível em: <https://www.wiley.com/en-us/Threat+Modeling%3A+Designing+for+Security-p-9781118809990>.

SOUPPAYA, M. et al. **NIST Secure Software Development Framework (SSDF): Recommendations for Mitigating the Risk of Software Vulnerabilities**. [S.l.], 2022. Disponível em: <https://doi.org/10.6028/NIST.SP.800-218>.

VERENDEL, V.; MCGRAW, G. Systematizing software weaknesses: A study of the common weakness enumeration (cwe). **Journal of Information Security and Applications**, Elsevier, v. 72, p. 103452, 2023.

WEE, A.; KUDRIAVTSEVA, A.; GADYATSKAYA, O. “have heard of it”: A study with practitioners on adoption of secure software development frameworks. In: **2024 IEEE European Symposium on Security and Privacy Workshops (EuroS&PW)**. [S.l.: s.n.], 2024. p. 626–633. ISSN 2768-0657.

WICAKSONO, H. R. et al. A design for comprehensive information system management framework integrating secure software development, resource management, and real-time monitoring. In: **2024 7th International Conference on Informatics and Computational Sciences (ICICoS)**. [S.l.: s.n.], 2024. p. 209–214. ISSN 2767-7087.

YIN, R. K. **Case Study Research: Design and Methods**. 5. ed. [S.l.]: SAGE Publications, 2014.

ZHAO, T. et al. Thriving in the era of hybrid work: Raising cybersecurity awareness using serious games in industry trainings. In: **2024 36th International Conference on Software Engineering Education and Training (CSEE&T)**. [S.l.: s.n.], 2024. p. 1–1. ISSN 2377-570X.

APÊNDICE A – ESTRUTURAS DE SAÍDA EM JSON DO CARCARÁ THREAT POKER

Este apêndice descreve as estruturas de saída em JSON utilizadas pelo *Carcará Threat Poker*. O objetivo do formato estruturado é permitir: (i) padronização dos resultados gerados pela IA consultiva; (ii) validação automatizável do conteúdo; (iii) rastreabilidade entre história de usuário, ameaças, classificações e decisões; e (iv) rápida conversão dos resultados em artefatos acionáveis no backlog (ex.: cards e ASPs). O conteúdo apresentado a seguir descreve a estrutura lógica dos objetos gerados nas Fases 1 e 2 do procedimento.

A.1 FASE 1 — JSON DE OPÇÕES DE AMEAÇA

A Fase 1 retorna um conjunto fixo de opções (A–D) contendo descrições curtas e comparáveis, focadas no problema (ameaça) e não em mitigação.

```
{
  "options": [
    { "id": "A", "description": "..." },
    { "id": "B", "description": "..." },
    { "id": "C", "description": "..." },
    { "id": "D", "description": "..." }
  ]
}
```

Em que:

- id: identificador da opção (A, B, C ou D);
- description: texto curto e claro descrevendo a ameaça, sem sugerir mitigação.

A.2 FASE 2 — JSON DE ANÁLISE TÉCNICA E INSUMOS PARA ASP

A Fase 2 retorna a análise técnica de cada opção e os insumos necessários para cálculo e registro do ASP, além de subtarefas e critérios objetivos de *Definition of Done* (DoD) de segurança.

```
{
  "analyzedOptions": [
    {
      "id": "A",
      "description": "...",

```

```

    "classificacoes": {
      "stride": [ "..."],
      "owasp_top10": "A01:2021-Broken Access Control",
      "cwe": "CWE-285"
    },
    "cheat_sheets": ["Access Control Cheat Sheet"],
    "insumos_asp": {
      "risco": "alto",
      "esforco": "médio",
      "escala": {
        "risco": { "baixo": 1, "médio": 3, "alto": 8, "crítico": 10 },
        "esforco": { "muito alto": 3, "alto": 5, "médio": 8, "baixo": 10 }
      },
      "calculado": "ASP = 8 x 8 = 64"
    },
    "subtarefas_sugeridas": [ "...", "..."],
    "dod_seguranca": [ "...", "..."]
  }
]
}

```

Em que:

- analyzedOptions: lista contendo uma entrada por opção (A–D);
- id e description: identificador e descrição textual da ameaça;
- classificacoes: classificações técnicas associadas à opção analisada;
 - stride: categorias STRIDE aplicáveis;
 - owasp_top10: categoria OWASP Top 10 mais aderente;
 - cwe: causa-raiz (CWE) principal.
- cheat_sheets: referência(s) a *OWASP Cheat Sheets* relacionadas à mitigação;
- insumos_asp: informações para priorização de ASP;
 - risco: rótulo estimado de risco (baixo, médio, alto, crítico);
 - esforco: rótulo estimado de esforço de mitigação (baixo, médio, alto, muito alto);
 - escala: mapeamento das escalas para valores numéricos utilizados no cálculo do ASP;

- calculo: expressão textual do cálculo, explicitando o score.
- subtarefas_sugeridas: lista de subtarefas acionáveis (curtas) para apoiar a execução;
- dod_seguranca: critérios objetivos de conclusão (*Definition of Done*) relacionados à mitigação.

A.3 OBSERVAÇÕES PARA VALIDAÇÃO E RASTREABILIDADE

A estrutura JSON foi concebida para permitir validação automática do esquema e facilitar rastreabilidade no fluxo ágil. Em particular, o campo `insumos_asp.calculo` torna explícita a priorização, enquanto as seções `subtarefas_sugeridas` e `dod_seguranca` auxiliam na conversão do resultado em itens executáveis no backlog. Recomenda-se que, ao registrar um card no backlog, a equipe mantenha o vínculo entre história de usuário, opção selecionada e ASP resultante, preservando a justificativa da decisão e permitindo revisão posterior.

APÊNDICE B – PROMPTS UTILIZADOS NO CARCARÁ THREAT POKER

Este apêndice documenta os prompts utilizados no procedimento do *Carcará Threat Poker* como apoio à modelagem de ameaças no contexto do método *CARCARÁ Agile Threat Modeling (CATM)*. O objetivo é garantir transparência e reprodutibilidade quanto às instruções fornecidas à IA consultiva, preservando o caráter não prescritivo do método: a IA atua como instrumento de apoio e a decisão final permanece sob responsabilidade do time.

B.1 FASE 1 — GERAÇÃO DE OPÇÕES DE AMEAÇA

A Fase 1 tem como finalidade gerar alternativas de ameaça para uma história de usuário, sem sugerir mitigação, permitindo que a equipe discuta e vote na hipótese considerada mais relevante.

Você é Mestre de Jogo **do** "*Carcará Threat Poker*", especialista em modelagem de ameaças com STRIDE.

Objetivo: ajudar a equipe a analisar riscos de forma educativa, gerando alternativas de ameaça (sem mitigações).

História de usuário:

`"${userStory}"`

Contexto adicional (opcional):

`"${contextoOpcional}"`

Instruções:

- Gere 4 alternativas distintas de ameaça (foco no PROBLEMA, não na solução).
- 2-3 opções devem ser ameaças relevantes; 1-2 podem ser menos prioritárias para contraste.
- Não inclua mitigação nesta fase.
- Não explique fora **do** JSON; não use markdown; não repita a história.

Saída OBRIGATÓRIA:

JSON com a chave `"options"`: **array** de objetos { `"id": "A|B|C|D"`, `"description": "texto curto e claro"` }.

Exemplo de formato (exatamente esta estrutura, sem comentários):

```
{ "options": [ { "id": "A", "description": "..."}, { "id": "B", "description": "..."}, { "id": "C", "description": "..."}, { "id": "D", "description": "..."} ] }
```

B.2 FASE 2 — ANÁLISE TÉCNICA E CÁLCULO DO ASP

A Fase 2 realiza a análise técnica das opções geradas na Fase 1 e produz insumos estruturados para discussão e priorização, incluindo classificações (STRIDE, OWASP Top 10, CWE), referências em *Cheat Sheets* e o cálculo do score ASP.

Você é Consultora Especialista em segurança. Analise tecnicamente CADA opção gerada na Fase 1.

Contexto:

- 1) User Story: "\${userStory}"
- 2) Opções de ameaça: "\${allOptionsString}"
- 3) Respostas/justificativas da equipe: "\${playerResponsesString}"
- 4) Contexto adicional: "\${contextoOpcional}"

Para CADA opção (A, B, C, D), faça:

1. Classificação STRIDE (uma ou mais).
2. Categoria OWASP Top 10 (a mais aderente).
3. Causa-raiz CWE (principal).
4. Boa prática correlata em OWASP Cheat Sheets (nome da cheat sheet ou seção).
5. Severidade/impacto (texto curto; CVSS apenas como referência informativa).
6. Estimar RISCO (R): um de { "baixo", "médio", "alto", "crítico" }.
7. Estimar ESFORÇO DE MITIGAÇÃO (EM): um de { "baixo", "médio", "alto", "muito alto" }.
8. Calcular ASP = $R \times EM$ (usar mapeamento interno: baixo=1, médio=3, alto=8, crítico=10; EM: muito alto=3, alto=5, médio=8, baixo=10). Exponha o cálculo.
9. Listar subtarefas acionáveis (bullet points curtos).
10. Definir DoD (Definition of Done) objetivo para a mitigação.

Regras:

- Não invente bibliografia; use apenas taxonomias pedidas.
- CVSS é informativo; a decisão final é da equipe.
- Responda SOMENTE no JSON especificado. Sem markdown, títulos ou texto livre.

Saída OBRIGATÓRIA:

```
{
  "analyzedOptions": [
    {
      "id": "A",
      "description": "...",
      "classificacoes": {
        "stride": [...],
        "owasp_top10": "A01:2021-Broken Access Control",
        "cwe": "CWE-285"
      },
      "cheat_sheets": ["Access Control Cheat Sheet"],
```



```
"insumos_asp": {
  "risco": "alto",
  "esforco": "médio",
  "escala": { "risco": {"baixo":1, "médio":3, "alto":8, "crítico":10},
              "esforco": {"muito alto":3, "alto":5, "médio":8, "baixo":10}},
  "calculo": "ASP = 8 x 8 = 64"
},
"subtarefas_sugeridas": [ "...", "..."],
"dod_seguranca": [ "...", "..."]
}
// repetir para B, C, D
]
```

B.3 OBSERVAÇÕES SOBRE SALVAGUARDAS E USO REPRODUTÍVEL

Os prompts adotam salvaguardas para garantir consistência de saída e reduzir ambiguidade, tais como: (i) exigência de saída exclusiva em JSON; (ii) uso controlado de taxonomias (STRIDE, OWASP Top 10, CWE e *Cheat Sheets*); (iii) cálculo explícito do ASP por escala predefinida; e (iv) caráter consultivo, no qual a decisão final de priorização e aceite permanece com a equipe. Além disso, recomenda-se que o conteúdo enviado como entrada ao prompt não inclua segredos, dados pessoais ou informações sensíveis do sistema, adotando mascaramento quando necessário.

APÊNDICE C – INSTRUMENTO DE COLETA E REGISTRO DO ESTUDO DE CASO

Este instrumento foi utilizado pelo pesquisador como guia operacional durante a condução do estudo de caso, funcionando como um caderno de campo estruturado para registro sistemático das observações realizadas ao longo das sprints analisadas.

A. IDENTIFICAÇÃO DA SPRINT

Projeto:

Sprint:

Período (início – fim):

Data da observação:

Cerimônia observada: ☐ Planning ☐ Daily ☐ Review ☐ Retrospective

B. HISTÓRIA(S) DE USUÁRIO ANALISADA(S)

Identificador da história:

Descrição resumida da história:

C. RESULTADOS DA MODELAGEM DE AMEAÇAS

Ameaça(s) identificada(s):

Classificação da ameaça:

Categoria STRIDE:

OWASP Top 10:

CWE:

CVSS:

Severidade / risco estimado:

D. ARTEFATOS DE SEGURANÇA PRODUZIDOS

() Card de segurança

() ASP criada/ajustada

() Critério de aceitação ajustado

() Registro de risco residual

Descrição dos artefatos produzidos:

E. DECISÕES DE SEGURANÇA

☐ Mitigar risco

☐ Aceitar risco

☐ Adiar mitigação

Justificativa discutida pela equipe:

Registro da decisão no fluxo (backlog, critério, outro):

F. IMPACTOS NO FLUXO DE DESENVOLVIMENTO

Planning:

Daily:

Review:

Retrospective:

Descrição das mudanças observadas:

G. OBSERVAÇÕES ANALÍTICAS DO PESQUISADOR

Integração da modelagem de ameaças ao Scrum:

Fluidez ou atritos percebidos:

APÊNDICE D – REGISTROS EMPÍRICOS DA SPRINT 17 — SPRINT PLANNING

Este apêndice apresenta os registros empíricos coletados durante a reunião de *Sprint Planning* da Sprint 17 do sistema *Bastião*. Os registros foram produzidos a partir do preenchimento do instrumento de coleta descrito no Apêndice A, refletindo as observações realizadas pelo pesquisador durante a aplicação do método *CARCARÁ Agile Threat Modeling (CATM)* no contexto real do projeto.

A. IDENTIFICAÇÃO DA SPRINT

Projeto:	Sistema Bastião
Sprint:	Sprint 17
Período:	09/12/2025 – 22/12/2025
Cerimônia observada:	Sprint Planning
Papel do pesquisador:	Observador participante

B. HISTÓRIAS DE USUÁRIO PLANEJADAS NA SPRINT

Durante o planejamento da Sprint 17, as seguintes histórias de usuário foram incluídas no backlog da sprint, abrangendo diferentes épicos do projeto:

- **US01 — Padronização do Tratamento de Exceções (API Error)**
- **US02 — Saneamento de Dados para Envio ao MNI**
- **US03 — Controle do Job de Etiquetagem PJe**
- **US04 — Padronização de Tipos de Arquivos (MIME types)**

Essas histórias refletem demandas funcionais, técnicas e de integração, compondo o escopo completo da sprint.

C. HISTÓRIAS SELECIONADAS PARA MODELAGEM DE AMEAÇAS

Dentre as histórias planejadas, apenas um subconjunto foi selecionado para aplicação explícita da modelagem de ameaças durante o *Sprint Planning*. A seleção seguiu critérios qualitativos definidos previamente no método, priorizando histórias que:

- envolvem integração com sistemas externos;
- manipulam dados sensíveis;
- afetam diretamente a robustez e confiabilidade do sistema.

Com base nesses critérios, foram selecionadas para análise pelo CATM as seguintes histórias:

- **US01 — Padronização do Tratamento de Exceções (API Error)**
- **US02 — Saneamento de Dados para Envio ao MNI**

As demais histórias permaneceram no fluxo regular da sprint, sem aplicação explícita da modelagem de ameaças nesta iteração.

D. RESULTADOS DA MODELAGEM DE AMEAÇAS

A aplicação do CATM sobre as histórias selecionadas resultou na identificação de ameaças relacionadas principalmente à exposição indevida de informações, validação insuficiente de dados e inconsistências no tratamento de erros.

Ameaças identificadas

- Exposição de informações internas em mensagens de erro retornadas por APIs;
- Injeção de caracteres inválidos em nomes de arquivos enviados ao MNI;
- Falhas de validação de dados de identificação (CPF) em payloads de integração.

Classificações técnicas

- **STRIDE**: Information Disclosure, Tampering
- **OWASP Top 10**:

- A02:2021 – Cryptographic Failures
- A03:2021 – Injection
- **CWE:** CWE-209 (Information Exposure Through an Error Message), CWE-20 (Improper Input Validation)
- **Severidade estimada:** Alta

E. ATIVIDADES DE SEGURANÇA PROATIVAS (ASP) CRIADAS

Com base na combinação de risco (R) e esforço de mitigação (EM), conforme definido no CATM, foram criadas apenas as **ASPs de maior valor**, evitando a pulverização de ações de segurança de baixo impacto.

Tabela 5 – ASPs criadas durante o planejamento da Sprint 17

ASP ID	Descrição	Score ASP
ASP-17-01	Padronizar o tratamento de exceções e respostas de erro da API utilizando a estrutura <code>ApiError</code> centralizada, evitando exposição de informações internas.	$R = 8, EM = 8$ $\Rightarrow$ 64
ASP-17-02	Implementar saneamento automático de nomes de arquivos e validação de CPF antes do envio de dados ao MNI.	$R = 8, EM = 10$ $\Rightarrow$ 80

Ambas as ASPs foram vinculadas diretamente às histórias analisadas e registradas no backlog da sprint como tarefas explícitas de segurança.

F. DECISÕES DE SEGURANÇA OBSERVADAS

Durante o planejamento, foram registradas as seguintes decisões:

- Mitigação das ameaças relacionadas à exposição de erros de API;
- Priorização das validações de dados de integração com o MNI;
- Não houve aceitação explícita de riscos nesta sprint.

G. OBSERVAÇÕES ANALÍTICAS DO PESQUISADOR

Observou-se que a seleção das histórias para modelagem de ameaças contribuiu para manter a cerimônia de planejamento com baixo impacto no tempo total. A discussão concentrou-se em poucas ASPs de alto valor, alinhadas ao princípio de antecipação de riscos sem comprometer a fluidez do Scrum.

APÊNDICE E – REGISTROS EMPÍRICOS DA SPRINT 17 — DAILY SCRUM

Este apêndice apresenta os registros empíricos coletados durante uma reunião de *Daily Scrum* da Sprint 17 do sistema *Bastião*. Os registros foram produzidos a partir do preenchimento do instrumento de coleta descrito no Apêndice A, com foco na observação de como as Atividades de Segurança Proativas (ASP), definidas no planejamento da sprint, influenciaram o acompanhamento diário do trabalho.

A. IDENTIFICAÇÃO DA OBSERVAÇÃO

Projeto:	Sistema Bastião
Sprint:	Sprint 17
Data da observação:	16/12/2025
Cerimônia observada:	Daily Scrum
Papel do pesquisador:	Observador participante

B. HISTÓRIAS E ASPs EM ACOMPANHAMENTO

Durante o *Daily Scrum*, foram acompanhadas as seguintes histórias de usuário e ASPs previamente definidas no planejamento da sprint:

- **US01 — Padronização do Tratamento de Exceções (API Error)**
- **US02 — Saneamento de Dados para Envio ao MNI**
- **ASP-17-01 — Padronização de respostas de erro da API**
- **ASP-17-02 — Saneamento e validação de dados para envio ao MNI**

C. EVIDÊNCIAS OBSERVADAS DURANTE O DAILY

Durante a reunião, os desenvolvedores relataram o andamento das tarefas e os impactos das ASPs no progresso da sprint. As seguintes evidências foram registradas:

- A ASP-17-01 foi mencionada como dependente de refatorações em classes de serviço já em andamento, sem impacto negativo no ritmo das tarefas funcionais;

- A ASP-17-02 exigiu ajustes adicionais em validações de entrada, levantando a necessidade de pequenos refinamentos no payload de integração com o MNI;
- Não foram relatados bloqueios técnicos diretamente relacionados às atividades de segurança.

D. DISCUSSÕES RELACIONADAS À SEGURANÇA

Observou-se que as discussões de segurança no *Daily Scrum* ocorreram de forma pontual e contextualizada, sem a introdução de um momento dedicado exclusivamente à segurança. As ASPs foram tratadas como tarefas regulares do backlog, sendo mencionadas apenas quando impactavam o andamento do trabalho.

E. IMPEDIMENTOS E RISCOS EMERGENTES

Nenhum impedimento crítico relacionado à segurança foi identificado durante a reunião. Também não foram registrados novos riscos que demandassem criação de ASPs adicionais nesta cerimônia, mantendo-se o foco do *Daily* no acompanhamento do progresso.

F. OBSERVAÇÕES ANALÍTICAS DO PESQUISADOR

A observação do *Daily Scrum* indica que as ASPs, quando bem definidas no planejamento, tendem a se integrar naturalmente ao acompanhamento diário das atividades. A ausência de novos artefatos ou rituais específicos de segurança reforça o caráter leve do CATM e sua compatibilidade com o fluxo do Scrum.

APÊNDICE F – REGISTROS EMPÍRICOS DA SPRINT 17 — SPRINT REVIEW

Este apêndice apresenta os registros empíricos coletados durante a reunião de *Sprint Review* da Sprint 17 do sistema *Bastião*. Os registros foram produzidos a partir do preenchimento do instrumento de coleta descrito no Apêndice A, com o objetivo de observar como as Atividades de Segurança Proativas (ASP), definidas no planejamento da sprint, foram implementadas, validadas e apresentadas aos stakeholders antes do início do recesso forense.

A. IDENTIFICAÇÃO DA OBSERVAÇÃO

Projeto:	Sistema Bastião
Sprint:	Sprint 17
Data da observação:	20/12/2025
Cerimônia observada:	Sprint Review
Papel do pesquisador:	Observador participante

B. HISTÓRIAS DE USUÁRIO E ASPs AVALIADAS

Durante a *Sprint Review*, foram apresentadas as seguintes histórias de usuário e Atividades de Segurança Proativas associadas, previamente definidas no planejamento da sprint:

- **US01 — Padronização do Tratamento de Exceções (API Error)**
- **US02 — Saneamento de Dados para Envio ao MNI**
- **ASP-17-01 — Padronização de respostas de erro da API**
- **ASP-17-02 — Saneamento e validação de dados para envio ao MNI**

As demais histórias da sprint (US03 e US04) foram apresentadas apenas sob a ótica funcional, não tendo sido objeto de avaliação explícita de segurança nesta cerimônia.

C. EVIDÊNCIAS APRESENTADAS

Durante a revisão, a equipe demonstrou evidências concretas relacionadas às ASPs implementadas, incluindo:

- Padronização das respostas de erro da API utilizando a estrutura *ApiError*, com remoção de mensagens internas sensíveis;
- Validação e saneamento automático de nomes de arquivos antes do envio ao MNI;
- Correção no envio de dados de identificação (CPF) no payload de integração;
- Atualização dos critérios de aceitação das histórias para incluir requisitos explícitos de segurança.

As demonstrações ocorreram de forma integrada à apresentação das funcionalidades, sem a criação de um momento exclusivo para segurança.

D. AVALIAÇÃO DO STATUS DAS ASPS

A Tabela 6 apresenta a situação das ASPs definidas no planejamento da Sprint 17, conforme observado durante a *Sprint Review*.

Tabela 6 – Status das ASPs avaliadas na Sprint Review da Sprint 17

ASP ID	Descrição resumida	Status
ASP-17-01	Padronização das respostas de erro da API para evitar exposição de informações internas.	Concluída
ASP-17-02	Saneamento e validação de dados enviados ao MNI.	Concluída

Não foram identificadas ASPs parcialmente concluídas ou adiadas nesta sprint.

E. DISCUSSÕES E FEEDBACKS RELACIONADOS À SEGURANÇA

Durante a *Sprint Review*, os participantes destacaram positivamente a melhoria na consistência das respostas de erro e a redução de falhas de integração com sistemas externos. Não foram levantadas novas preocupações de segurança que demandassem a criação de ASPs adicionais no encerramento da sprint.

Observou-se que os aspectos de segurança foram tratados como parte natural da entrega, reforçando a percepção de que as ASPs estavam integradas ao incremento funcional do produto.

F. RISCO RESIDUAL OBSERVADO

Não foram registrados riscos residuais explícitos associados às histórias analisadas. A equipe considerou que as principais ameaças identificadas no planejamento da sprint foram mitigadas de forma satisfatória dentro do escopo definido.

G. OBSERVAÇÕES ANALÍTICAS DO PESQUISADOR

A observação da *Sprint Review* indica que as ASPs definidas no planejamento da Sprint 17 foram plenamente incorporadas às entregas apresentadas. A ausência de retrabalho ou questionamentos adicionais relacionados à segurança sugere que a antecipação das discussões de risco no planejamento contribuiu para maior previsibilidade e qualidade das entregas. O encerramento da sprint antes do recesso forense reforçou o caráter de consolidação das decisões e práticas adotadas.

APÊNDICE G – REGISTROS EMPÍRICOS DA SPRINT 17 — SPRINT RETROSPECTIVE

Este apêndice apresenta os registros empíricos coletados durante a reunião de *Sprint Retrospective* da Sprint 17 do sistema *Bastião*. Os registros foram produzidos a partir do preenchimento do instrumento de coleta descrito no Apêndice A, com o objetivo de observar as percepções da equipe sobre a integração da modelagem de ameaças ao fluxo de desenvolvimento ágil e identificar ajustes acordados para as próximas iterações.

A. IDENTIFICAÇÃO DA OBSERVAÇÃO

Projeto:	Sistema Bastião
Sprint:	Sprint 17
Data da observação:	21/12/2025
Cerimônia observada:	Sprint Retrospective
Papel do pesquisador:	Observador participante

B. PONTOS POSITIVOS OBSERVADOS

Durante a retrospectiva, a equipe destacou como aspectos positivos relacionados à introdução da modelagem de ameaças:

- A antecipação de discussões de segurança no planejamento reduziu dúvidas durante a implementação;
- A definição clara das ASPs contribuiu para maior previsibilidade do trabalho;
- A integração das atividades de segurança ao backlog evitou retrabalho próximo ao encerramento da sprint;
- A ausência de novos rituais ou papéis facilitou a aceitação da prática.

C. PONTOS DE ATENÇÃO E DIFICULDADES

Também foram relatados pontos de atenção associados ao uso inicial da abordagem:

- Necessidade de maior familiaridade da equipe com classificações técnicas (OWASP Top 10 e CWE);
- Percepção de aumento mínimo no tempo do *Sprint Planning* quando histórias críticas eram analisadas;
- Dependência inicial do apoio da ferramenta *Threat Poker* para orientar a discussão de riscos.

Nenhum dos pontos foi considerado impeditivo para a continuidade da abordagem.

D. AJUSTES DECIDIDOS PARA PRÓXIMAS SPRINTS

Como resultado da retrospectiva, a equipe acordou os seguintes ajustes incrementais para as próximas iterações:

- Manter a seleção criteriosa de histórias para modelagem de ameaças, priorizando apenas aquelas de maior risco;
- Refinar gradualmente o entendimento das escalas de risco (R) e esforço de mitigação (EM);
- Registrar de forma mais explícita os critérios de segurança nos critérios de aceitação das histórias analisadas;
- Retomar a aplicação da modelagem de ameaças de forma contínua após o recesso forense.

Não foi decidida a criação de novos artefatos ou cerimônias relacionadas à segurança.

E. IMPACTOS NO PROCESSO ÁGIL

A retrospectiva evidenciou que a introdução da modelagem de ameaças não alterou a estrutura do Scrum adotado pelo projeto, mas ampliou o escopo das discussões durante as cerimônias existentes. A segurança passou a ser tratada como parte integrante da qualidade do produto, e não como uma etapa posterior ou externa ao fluxo ágil.

F. OBSERVAÇÕES ANALÍTICAS DO PESQUISADOR

A observação da *Sprint Retrospective* indica que a equipe percebeu valor prático na introdução da modelagem de ameaças, especialmente pela antecipação de riscos e pela clareza das decisões tomadas. O caráter leve da abordagem foi considerado essencial para sua aceitação, reforçando a adequação do CATM ao contexto do projeto e ao período de encerramento do ano, marcado pelo recesso forense.

APÊNDICE H – RETORNO DO THREAT POKER — HISTÓRIA US01

Este apêndice apresenta os registros da aplicação da ferramenta *Threat Poker* durante a análise da história de usuário **US01 — Padronização do Tratamento de Exceções (API Error)**. A sessão foi conduzida durante o planejamento da Sprint 17.

F.1 AMEAÇA PRINCIPAL IDENTIFICADA

- Exposição de informações internas sensíveis em mensagens de erro da API.

F.2 DISCUSSÃO E JUSTIFICATIVAS

- A equipe identificou que exceções não tratadas podem revelar detalhes da estrutura interna do sistema, como nomes de classes, endpoints ou stacktraces, representando um risco de **Information Disclosure**.
- Participantes destacaram que já houve incidentes anteriores relacionados à divulgação de informações técnicas em ambientes de homologação.
- Foi considerada a possibilidade de reutilizar uma estrutura centralizada para tratamento de erros, reduzindo esforço de mitigação.

F.3 CLASSIFICAÇÃO ATRIBUÍDA

- **Risco (R)**: 8 — Considerado alto, pois a falha pode ser explorada em múltiplos endpoints.
- **Esforço de Mitigação (EM)**: 8 — Refatorar usando estrutura *ApiError* existente.
- **Score ASP**: $8 \times 8 = 64$

F.4 ASP DEFINIDA

- **ASP-17-01**: Padronizar respostas de erro da API utilizando a estrutura *ApiError*, removendo mensagens internas e sensíveis.

APÊNDICE I – RETORNO DO THREAT POKER — HISTÓRIA US02

Este apêndice apresenta os registros da aplicação da ferramenta *Threat Poker* durante a análise da história de usuário **US02 — Saneamento de Dados para Envio ao MNI**.

G.1 AMEAÇAS PRINCIPAIS IDENTIFICADAS

- Envio de dados inconsistentes (ex: nome de arquivo com caracteres inválidos).
- Falhas na validação de CPF antes do envio, gerando erros na integração.

G.2 DISCUSSÃO E JUSTIFICATIVAS

- O histórico de falhas na comunicação com o sistema do MNI foi mencionado como evidência do risco.
- O saneamento automático de nomes de arquivos e validação de CPF já existia em outro módulo, podendo ser reaproveitado.
- A ameaça foi classificada como **Tampering** e **Injection**, com referência ao CWE-20 e CWE-116.

G.3 CLASSIFICAÇÃO ATRIBUÍDA

- **Risco (R)**: 8 — Alto impacto, pois pode bloquear envio de dados ao MNI.
- **Esforço de Mitigação (EM)**: 10 — Implementação de sanitização e validação em múltiplos campos.
- **Score ASP**: $8 \times 10 = 80$

G.4 ASP DEFINIDA

- **ASP-17-02**: Implementar saneamento automático de nomes de arquivos e validação de CPF antes do envio ao MNI.